Jr.Pen 6. Burp Suite

1. Burp Suite: The Basics

Task 1 - Introduction

The core of the Burp Suite framework is the Burp Proxy.

Task 2 - What is Burp Suite

Burp Suite is a Java-based framework designed to serve as a comprehensive solution for conducting web application penetration testing. It has become the industry standard tool for hands-on security assessments of web and mobile applications, including those that rely on application programming interfaces (APIs). Burp Suite captures and enables manipulation of all the HTTP/HTTPS traffic between a browser and a web server. This fundamental capability forms the backbone of the framework. By intercepting requests, users have the flexibility to route them to various components within the Burp Suite framework, which we will explore in upcoming sections. The ability to intercept, view, and modify web requests before they reach the target server or even manipulate responses before they are received by our browser makes Burp Suite an invaluable tool for manual web application testing.

> Which edition of Burp Suite runs on a server and provides constant scanning for target web apps? Burp Suite Enterprise

> Burp Suite is frequently used when attacking web applications and applications. Mobile

Task 3 - Features of Burp Community

Proxy: allows us to intercept and modify requests/responses when interacting with web applications.
Repeater: allows us to capture, modify, then resend the same request numerous times.
Intruder: allows us to spray an endpoint with requests. This is often used for bruteforce attacks or to fuzz endpoints.

Decoder: allows us to decode captured information, or encode a payload prior to sending it to the target.
Comparer: allows us to compare two pieces of data at either word or byte level.
Sequencer: allows us to assess the randomness of tokens such as session cookie values or other supposedly random generated data. If the algorithm is not generating secure random values, then this could open up some devastating avenues for attack.

> Which Burp Suite feature allows us to intercept requests between ourselves and the target? Proxy

> Which Burp tool would we use to brute-force a login form? Intruder

Task 4 - Installation

Install Burp Suite using the appropriate method for your operating system.

Task 5 - The Dashboard

After opening Burp Suite Community and opening a new project you are met by the Burp Dashboard.

In short, the Dashboard interface is split into four quadrants:

1. The Tasks menu allows us to define background tasks that Burp Suite will run whilst we use the application.
2. The Event log tells us what Burp Suite is doing (e.g. starting the Proxy), as well as information about any connections that we are making through Burp.
3. The Issue Activity section is exclusive to Burp Pro. It won't give us anything using Burp Community, but in Burp Professional it would list all of the vulnerabilities found by the automated scanner.
4. The Advisory section gives more information about the vulnerabilities found, as well as references and suggested remediations. These could then be exported into a report.

Task 6 - Navigation

Navigating around the Burp Suite GUI by default is done entirely using the top menu bars. These allow you to switch between modules. If the selected module

has more than one sub-tab, then these can be selected using a second menu bar which appears directly below the original bar. Ctrl + Shift + D Switch to the Dashboard Ctrl + Shift + T Switch to the Target tab Ctrl + Shift + P Switch to the Proxy tab Ctrl + Shift + I Switch to the Intruder tab Ctrl + Shift + R Switch to the Repeater tab.

Task 7 - Options

There are two type of settings available for configuring Burp Suite.

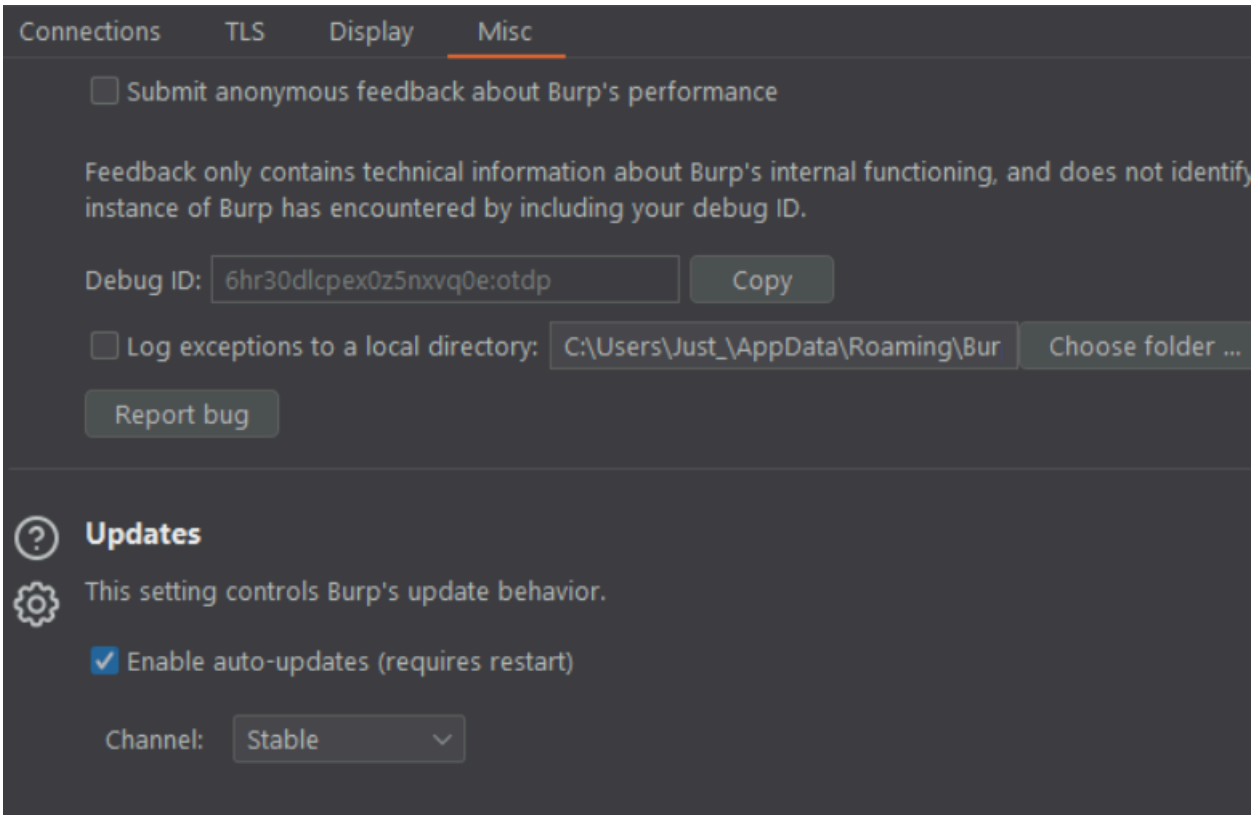
1. Global settings can be found in the User options tab along the top menu bar.
2. Project-specific settings can be found in the Project options tab.

> In which category can you find a reference to a "Cookie jar"? Sessions

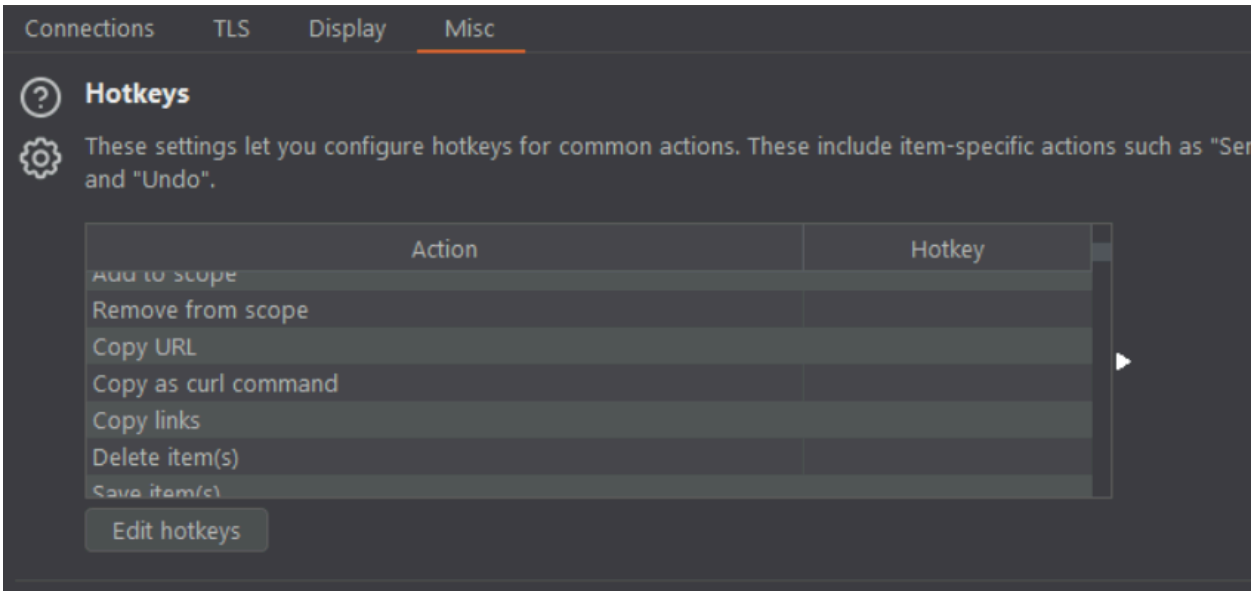
> In which base category can you find the "Updates" sub-category, which controls the Burp Suite update behaviour? Suite



> What is the name of the sub-category which allows you to change the keybindings for shortcuts in Burp Suite? Hotkeys

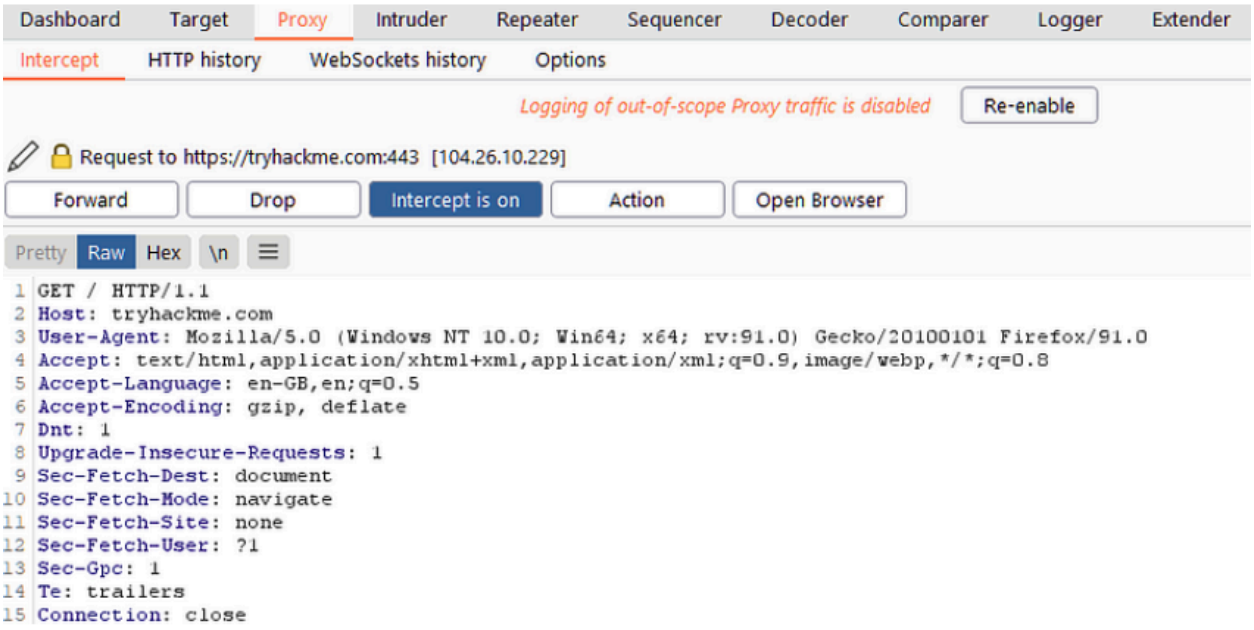


> If we have uploaded Client-Side TLS certificates, can we override these on a per-project basis (yea/nay)? yea



Task 8 - Introduction to the Burp Proxy

The Burp Proxy is a fundamental and crucial tool within Burp Suite. It enables the capture of requests and responses between the user and the target web server. This intercepted traffic can be manipulated, sent to other tools for further processing, or explicitly allowed to continue to its destination.



Intercepting Requests: When requests are made through the Burp Proxy, they are intercepted and held back from reaching the target server. The requests appear in the Proxy tab, allowing for further actions such as forwarding, dropping, editing, or sending them to other Burp modules. To disable the intercept and allow requests to pass through the proxy without interruption, click the Intercept is on button.

Taking Control: The ability to intercept requests empowers testers to gain complete control over web traffic, making it invaluable for testing web applications.

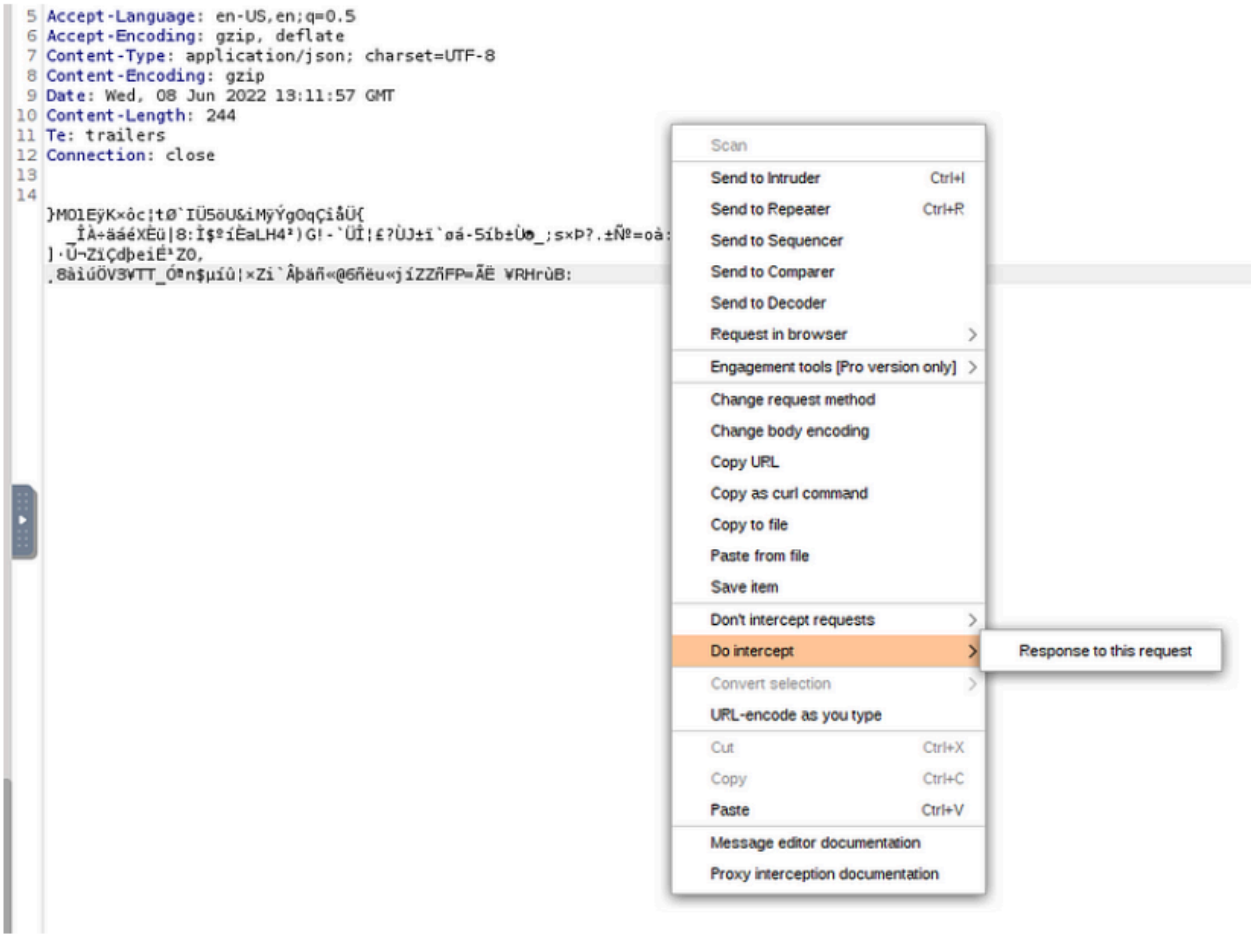
Capture and Logging: Burp Suite captures and logs requests made through the proxy by default, even when the interception is turned off. This logging functionality can be helpful for later analysis and review of prior requests.

WebSocket Support: Burp Suite also captures and logs WebSocket communication, providing additional assistance when analysing web applications.

Logs and History: The captured requests can be viewed in the HTTP history and WebSockets history sub-tabs, allowing for retrospective analysis and sending the requests to other Burp modules as needed.

Task 9 - Connecting through the Proxy (FoxyProxy)

There are two ways to proxy our traffic through Burp Suite. We could use the embedded browser. We can configure our local web browser to proxy our traffic through Burp; this is more common and so will be the focus of this task. The Burp Proxy works by opening a web interface on 127.0.0.1:8080 (by default). As implied by the fact that this is a "proxy", we need to redirect all of our browser traffic through this port before we can start intercepting it with Burp. We can do this by altering our browser settings or, more commonly, by using a Firefox browser extension called FoxyProxy. FoxyProxy allows us to save proxy profiles, meaning we can quickly and easily switch to our "Burp Suite" profile in a matter of clicks, then disable the proxy just as easily.



Finding the **do intercept response to this request** button

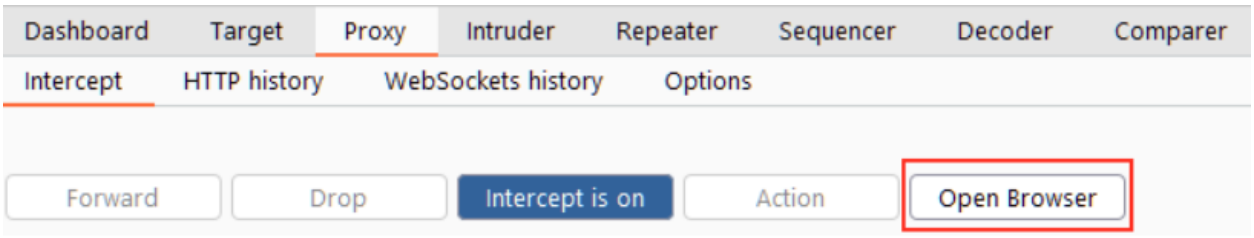
Task 10 - Site Map and Issue Definitions

It consists of three sub-tabs: Site map, Issue definitions, Scope settings.

Task 11 - The Burp Suite Browser

We can start the Burp Browser with the “Open Browser” button in the proxy tab. There are two simple solutions to this:

1. The smart option: We could create a new user and run Burp Suite under a low privilege account.
2. The easy option: We could go to Project options → Misc → Embedded Browser and check the Allow the embedded browser to run without a sandbox option.

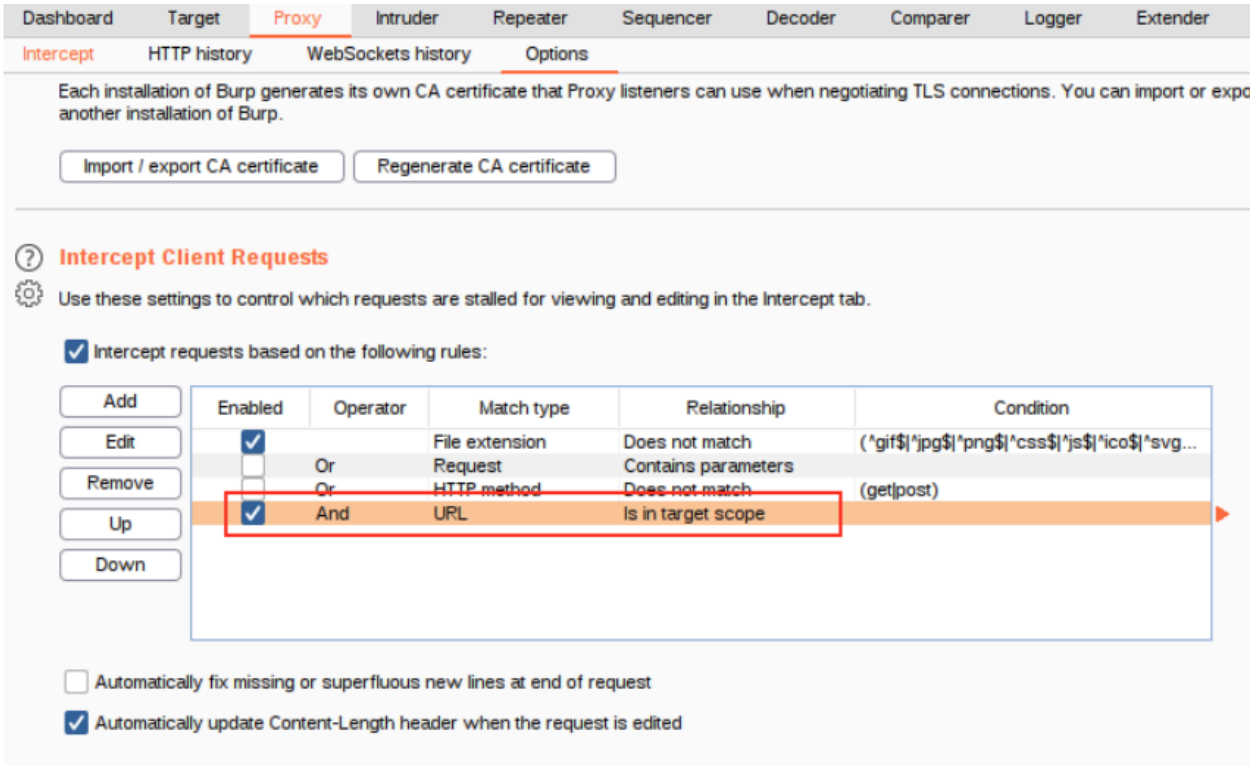


Task 12 - Scoping and Targeting

Scoping can get extremely tedious having Burp capturing all of our traffic. When it logs everything (including traffic to sites we aren't targeting), it muddies up logs we may later wish to send to clients. In short, allowing Burp to capture everything can quickly become a massive pain. Setting a scope for the project allows us to define what gets proxied and logged. The easiest way to do this is by switching over to the "Target" tab, right-clicking our target from our list on the left, then choosing "Add To Scope".

There are three sub-tabs under *Target*:

- **Site map** allows us to map out the apps we are targeting in a tree structure. Every page that we visit will show up here, allowing us to automatically generate a site map for the target simply by browsing around the web app.
- **Scope:** We have already seen the Scope sub-tab — it allows us to control Burp's target scope for the project.
- **Issue Definitions:** Whilst we don't have access to the Burp Suite vulnerability scanner in Burp Community, we do still have access to a list of all the vulnerabilities it looks for. The Issue Definitions section gives us a huge list of web vulnerabilities (complete with descriptions and references).



Adjusting intercept target scope settings

Task 13 - Proxying HTTPS

When intercepting HTTP traffic, you may encounter errors on sites with TLS enabled, such as receiving a message indicating that the PortSwigger Certificate Authority (CA) is not trusted. To resolve this, you need to add the PortSwigger CA certificate to your browser's trusted list. Here's how to do it:

1. **Download the CA Certificate:**
    - With Burp Proxy activated, navigate to `http://burp/cert` to download the `cacert.der` file. Save it on your machine.
2. **Access Firefox Certificate Settings:**
    - Type `about:preferences` in the Firefox URL bar and press Enter.
    - Search for "certificates" and click on **View Certificates**.
3. **Import the CA Certificate:**
    - In the **Certificate Manager** window, click **Import** and select the `cacert.der` file you downloaded.

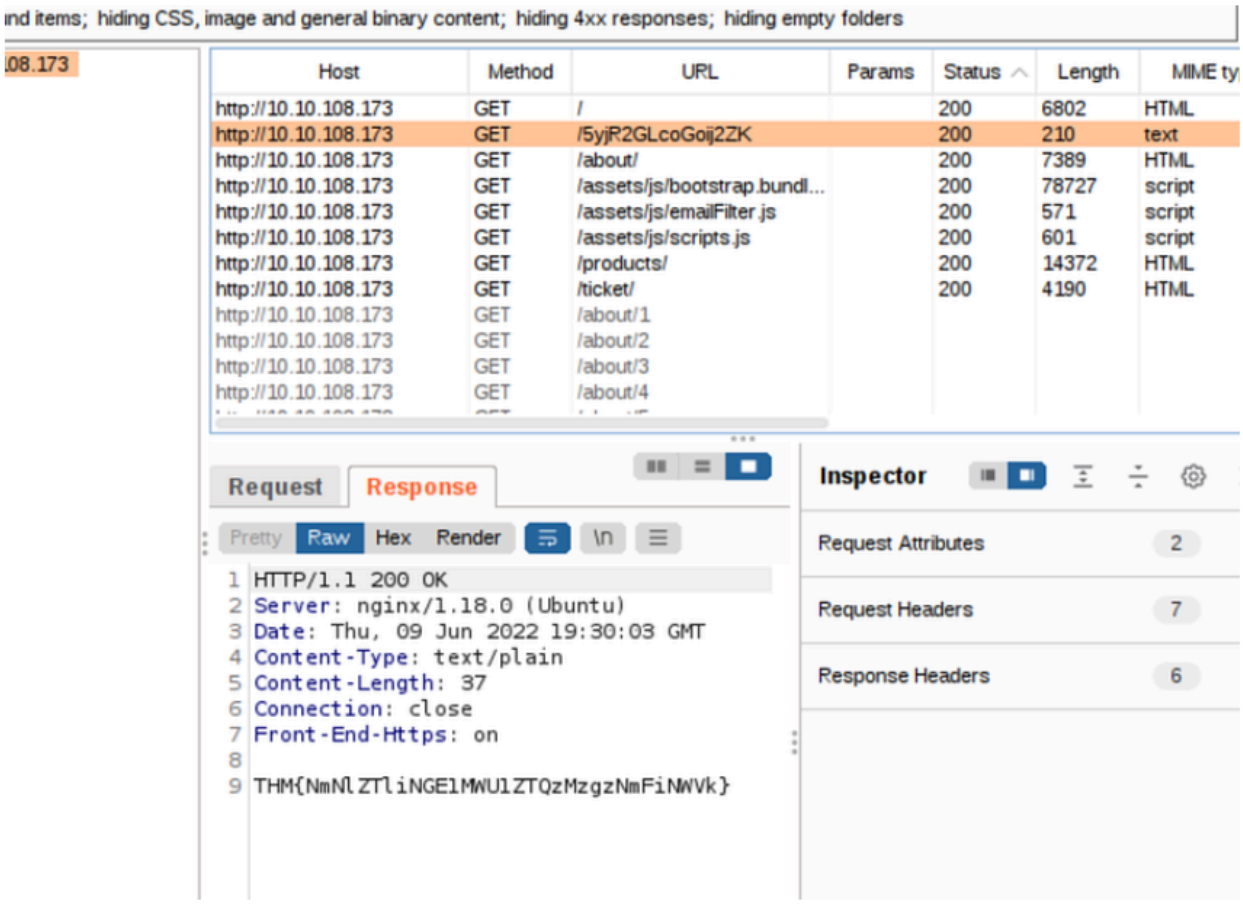
4. **Set Trust for the Certificate:**
    - In the trust settings window, check the box **Trust this CA to identify websites** and click **OK**.

After completing these steps, your browser will trust the PortSwigger CA certificate, allowing you to visit TLS-enabled sites through Burp Suite Proxy without encountering certificate errors.

Task 14 - Example Attack

Here's a step-by-step guide to bypassing this filter and triggering a **Reflected XSS** attack:

1. **Start by ensuring your Burp Proxy is active** and the **intercept** is on.
2. **Submit legitimate data** in the support form. For instance:
    - Email: `pentester@example.thm`
    - Query: `Test Attack`
3. **Intercept the request**: Once you submit the form, Burp Proxy will capture the request.
4. **Modify the request**:
    - Change the email field to your XSS payload: `<script>alert("Succ3ssful XSS")</script>`.
5. **URL encode the payload**: Select the payload and press `Ctrl + U` to URL encode it, ensuring it can be safely sent through the form.
6. **Forward the request**: Press the "Forward" button in Burp Proxy to send the modified request to the server.
7. **Check the result**: If successful, the website should display an alert box indicating that the XSS payload was executed, confirming the vulnerability.



Finding the flag in the sitemap

Task 15 - Conclusion

Have a solid foundation in Burp Suite, including the interface, configuration options, and the Burp Proxy. These skills are crucial for your journey into web and mobile application penetration testing. To continue improving, it's a great idea to practice and experiment with Burp Suite. Explore its features, tweak different settings, and familiarize yourself with all the available tools. The more you use Burp Suite, the better you'll become at identifying and exploiting vulnerabilities in web applications.

2. Burp Suite: Repeater

Task 1 - Introduction

Explore the advanced capabilities of the Burp Suite framework by focusing on the Burp Suite Repeater module.

Task 2 - What is Repeater?

Burp Suite Repeater enables us to modify and resend intercepted requests to a target of our choosing. It allows us to take requests captured in the Burp Proxy and manipulate them, sending them repeatedly as needed.

Request List: Located at the top left of the tab, it displays the list of Repeater requests. Multiple requests can be managed simultaneously, and each new request sent to Repeater will appear here.

Request Controls: Positioned directly beneath the request list, these controls allow us to send a request, cancel a hanging request, and navigate through the request history.

Request and Response View: Occupying the majority of the interface, this section displays the Request and Response views. We can edit the request in the Request view and then forward it, while the corresponding response will be shown in the Response view.

Layout Options: Located at the top-right of the Request/Response view, these options enable us to customize the layout of the Request and Response views. The default setting is a side-by-side (horizontal) layout, but we can also choose a vertical layout or combine them in separate tabs.

Inspector: Positioned on the right-hand side, the Inspector allows us to analyze and modify requests in a more intuitive manner than using the raw editor. We will explore this feature in a later task.

Target: Situated above the Inspector, the Target field specifies the IP address or domain to which the requests are sent. When requests are sent to Repeater from other Burp Suite components, this field is automatically populated.

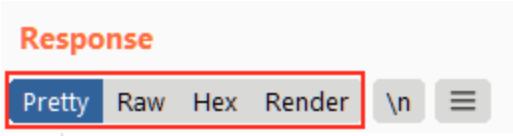
Task 3 - Basic Usage

Once a request has been captured in the Proxy module, we can send it to Repeater by either right-clicking on the request and selecting Send to Repeater, or by utilizing the keyboard shortcut Ctrl + R. Shifting our focus back to Repeater.

> Which view will populate when sending a request from the Proxy module to Repeater? Request

Task 4 - Message Analysis Toolbar

Repeater provides us with various request and response presentation options, ranging from hexadecimal output to a fully rendered page. To explore these options, we can refer to the section located above the response box, where the following four view buttons are available:



We are presented with the following display choices:

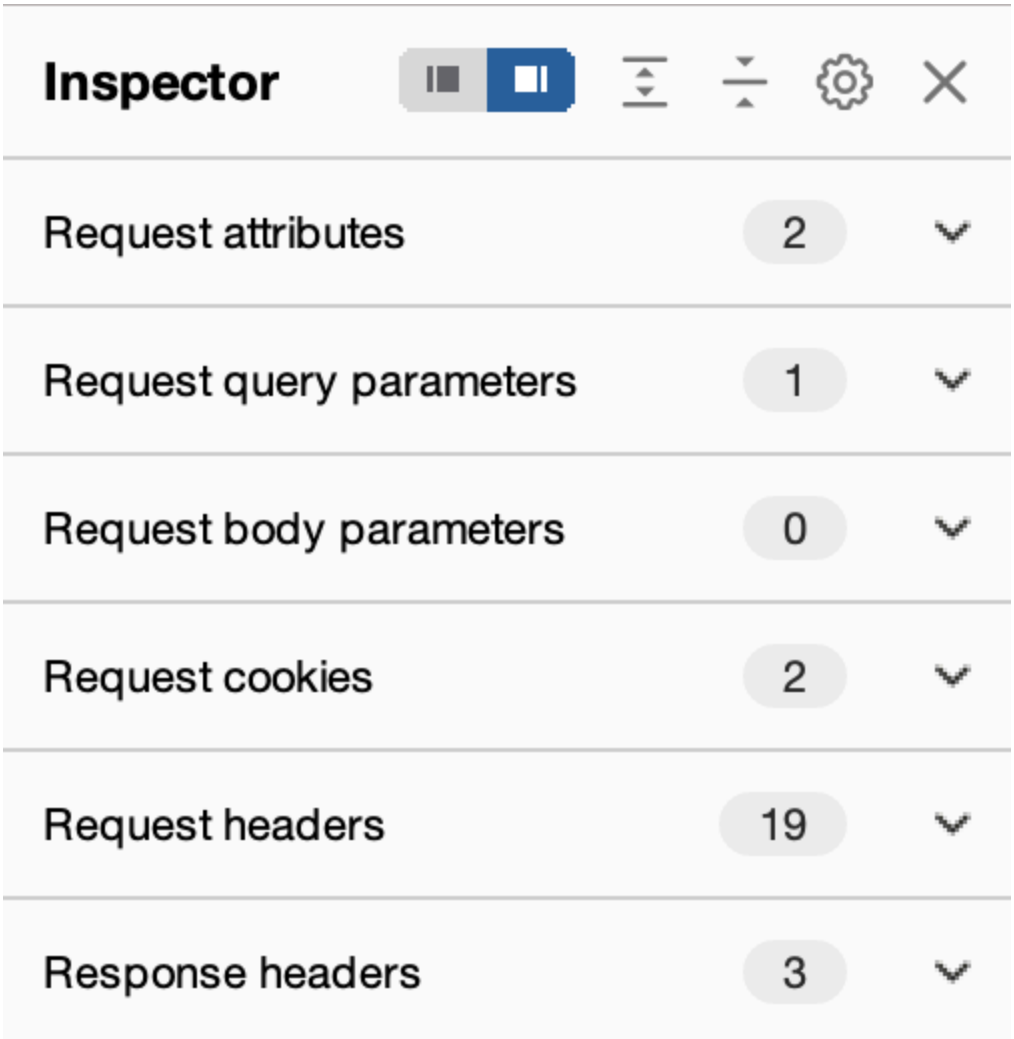
1. **Pretty**: This is the default option, which takes the raw response and applies slight formatting enhancements to improve readability.
2. **Raw**: This option displays the unmodified response directly received from the server without any additional formatting.
3. **Hex**: By selecting this view, we can examine the response in a byte-level representation, which is particularly useful when dealing with binary files.
4. **Render**: The render option allows us to visualize the page as it would appear in a web browser. While not commonly utilised in Repeater, as our focus is usually on the source code, it still offers a valuable feature. For most scenarios, the **Pretty** option is generally sufficient. However, it is beneficial to be acquainted with the usage of the other three options.

> Which option allows us to visualize the page as it would appear in a web browser? render

Task 5 - Inspector

Inspector is a supplementary feature to the Request and Response views in the Repeater module. It is also used to obtain a visually organized breakdown of requests and responses, as well as for experimenting to see how changes made using the higher-level Inspector affect the equivalent raw versions. Inspector can

be utilized both in the Proxy and Repeater module. In both instances, it is situated on the far-right side of the window, presenting a list of components within the request and response:



Among these components, the sections pertaining to the request can typically be modified, enabling the addition, editing, and removal of items. For instance, in the **Request Attributes** section, we can alter elements related to the location, method, and protocol of the request. This includes modifying the desired resource to retrieve, changing the HTTP method from GET to another variant, or switching the protocol from HTTP/1 to HTTP/2:



Other sections available for viewing and/or editing include:

1. **Request Query Parameters:** These refer to data sent to the server via the URL. For example, in a GET request like `https://admin.tryhackme.com/?redirect=false`, the query parameter **redirect** has a value of "false".
2. **Request Body Parameters:** Similar to query parameters, but specific to POST requests. Any data sent as part of a POST request will be displayed in this section, allowing us to modify the parameters before resending.
3. **Request Cookies:** This section contains a modifiable list of cookies sent with each request.
4. **Request Headers:** It enables us to view, access, and modify (including adding or removing) any headers sent with our requests. Editing these headers can be valuable when examining how a web server responds to unexpected headers.
5. **Response Headers:** This section displays the headers returned by the server in response to our request. It cannot be modified, as we have no control over the headers returned by the server. Note that this section becomes visible only after sending a request and receiving a response.

> Which section in Inspector is specific to POST requests? Body Parameters

Task 6 - Practical Example

Repeater is particularly well-suited for tasks requiring repetitive sending of similar requests, typically with minor modifications. This is particularly useful for activities such as manual testing for SQL Injection vulnerabilities, attempting to bypass web application firewall filters, or adjusting parameters in a form submission.

Task 7 - Challenge

In the previous task, we demonstrated the usage of Repeater by adding a header and sending a request. This served as an illustrative example for utilizing Repeater. Now, it's time for a straightforward challenge!

Task 8 - Extra-mile Challenge

This task contains an extra-mile challenge, which means that it is a slightly harder, real-world application for Burp Repeater. If you feel comfortable performing a manual SQL Injection by yourself. Adding a single apostrophe (') is usually enough to cause the server to error when a simple SQLi is present.

Task 9 - Conclusion

By now, you should have a solid understanding of effectively utilising Repeater to edit, manipulate, and resend requests. Additionally, you should have gained insight into the numerous practical applications of this tool.

3. Burp Suite: Intruder

Task 1 - Introduction

Burp Suite’s Intruder module, which offers automated request manipulation and enables tasks such as fuzzing and brute-forcing. Burp Suite’s Intruder module is a powerful tool that allows for automated and customisable attacks. It provides the ability to modify specific parts of a request and perform repetitive tests with variations of input data. Intruder is particularly useful for tasks like fuzzing and brute-forcing, where different values need to be tested against a target.

Task 2 - What is Intruder

Intruder is Burp Suite’s built-in fuzzing tool that allows for automated request modification and repetitive testing with variations in input values. By using a captured request (often from the Proxy module), Intruder can send multiple requests with slightly altered values based on user-defined configurations. It serves various purposes, such as brute-forcing login forms by substituting username and password fields with values from a wordlist or performing fuzzing

attacks using wordlists to test subdirectories, endpoints, or virtual hosts. Intruder's functionality is comparable to command-line tools like **Wfuzz** or **ffuf**.



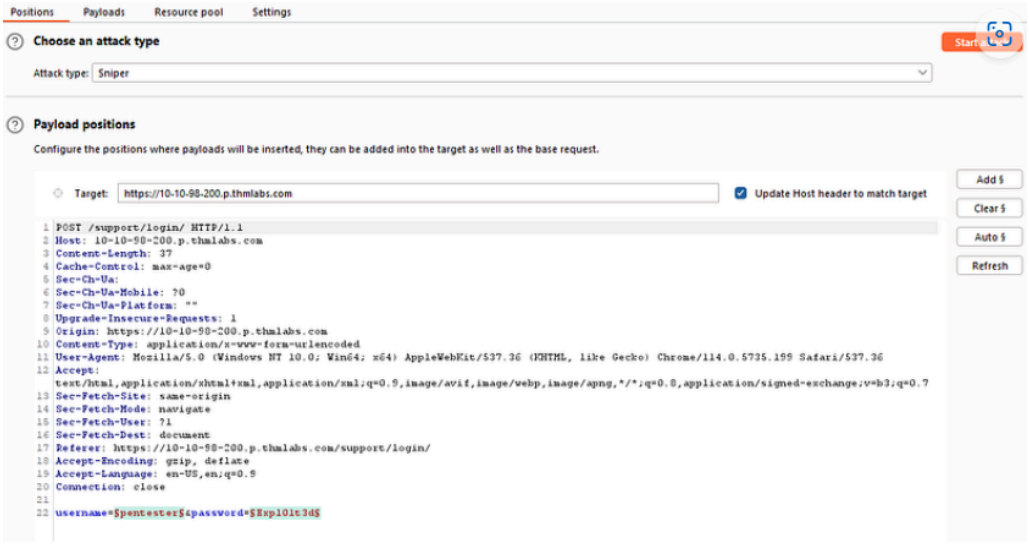
There are four sub-tabs within Intruder:

Positions: This tab allows us to select an attack type (which we will cover in a future task) and configure where we want to insert our payloads in the request template.
Payloads: Here we can select values to insert into the positions defined in the Positions tab. We have various payload options, such as loading items from a wordlist. The way these payloads are inserted into the template depends on the attack type chosen in the Positions tab. The Payloads tab also enables us to modify Intruder's behavior regarding payloads, such as defining pre-processing rules for each payload (e.g., adding a prefix or suffix, performing match and replace, or skipping payloads based on a defined regex).
Resource Pool: This tab is not particularly useful in the Burp Community Edition. It allows for resource allocation among various automated tasks in Burp Professional. Without access to these automated tasks, this tab is of limited importance.
Settings: This tab allows us to configure attack behavior. It primarily deals with how Burp handles results and the attack itself. For instance, we can flag requests containing specific text or define Burp's response to redirect (3xx) responses.

> In which Intruder tab can we define the "Attack type" for our planned attack?
> Positions

Task 3 - Positions

When using Burp Suite Intruder to perform an attack, the first step is to examine the positions within the request where we want to insert our payloads.

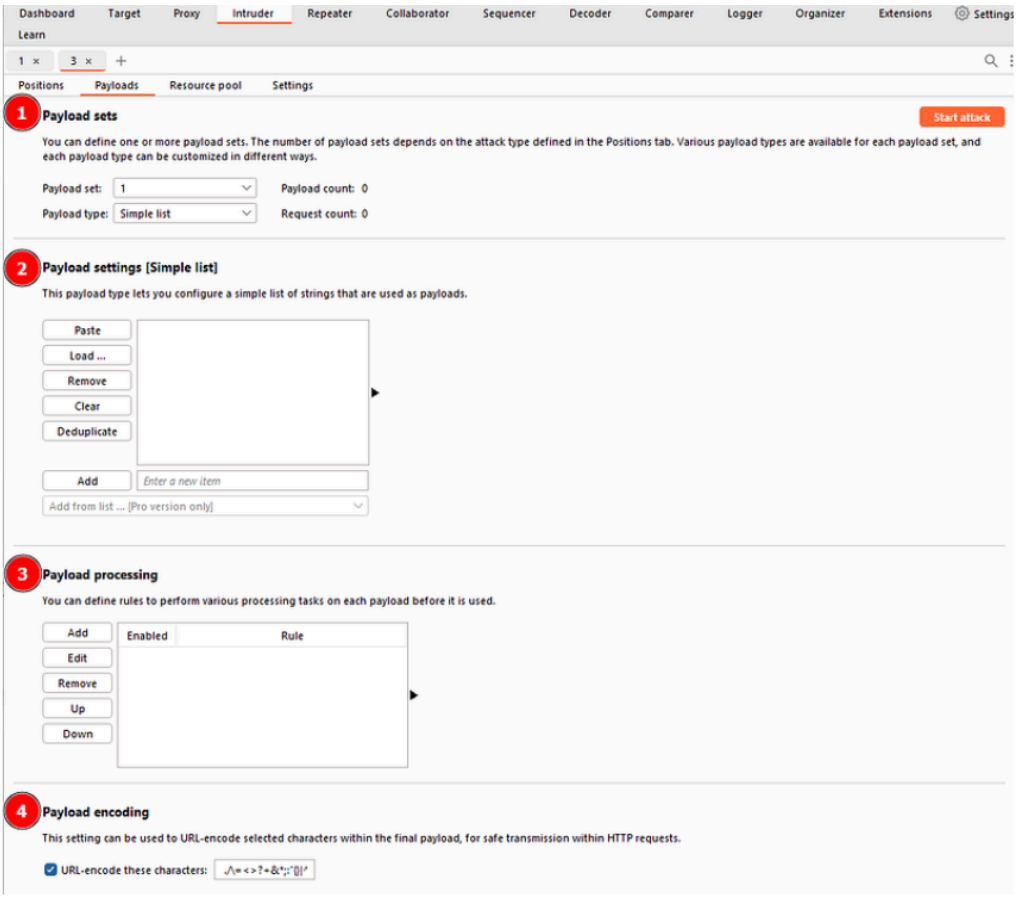


Notice that Burp Suite automatically attempts to identify the most probable positions where payloads can be inserted. These positions are highlighted in green and enclosed by section marks **(** `§` **)**.

> What symbol defines the start and the end of a payload position? §

Task 4 - Payloads

In the **Payloads** tab of Burp Suite Intruder, we can create, assign, and configure payloads for our attack.



Payload Sets: This section allows us to choose the position for which we want to configure a payload set and select the type of payload we want to use.

Payload settings: This section provides options specific to the selected payload type for the current payload set.

Payload Processing: In this section, we can define rules to be applied to each payload in the set before it is sent to the target.

Payload Encoding: The section allows us to customize the encoding options for our payloads.

> Which Payload processing rule could we use to add characters at the end of each payload in the set? Add suffix

Task 5 - Introduction to Attack Types

The Positions tab of Burp Suite Intruder has a dropdown menu for selecting the attack type. Intruder offers four attack types, each serving a specific purpose.

Sniper: The Sniper attack type is the default and most commonly used option. It cycles through the payloads, inserting one payload at a time into each position defined in the request. Sniper attacks iterate through all the payloads in a linear fashion, allowing for precise and focused testing.
Battering ram: The Battering ram attack type differs from Sniper in that it sends all payloads simultaneously, each payload inserted into its respective position. This attack type is useful when testing for race conditions or when payloads need to be sent concurrently.
Pitchfork: The Pitchfork attack type enables the simultaneous testing of multiple positions with different payloads. It allows the tester to define multiple payload sets, each associated with a specific position in the request. Pitchfork attacks are effective when there are distinct parameters that need separate testing.
Cluster bomb: The Cluster bomb attack type combines the Sniper and Pitchfork approaches. It performs a Sniper-like attack on each position but simultaneously tests all payloads from each set. This attack type is useful when multiple positions have different payloads, and we want to test them all together.

> What attack type cycles through the payloads inserting one payload at a time into each position defined in the request? Sniper

Task 6 - Sniper

The **Sniper** attack type is the default and most commonly used attack type in Burp Suite Intruder. It is particularly effective for single-position attacks, such as password brute-force or fuzzing for API endpoints. The Sniper attack type is beneficial when we want to perform tests with single-position attacks, utilizing different payloads for each position. It allows for precise testing and analysis of different payload variations.

> If you were using Sniper to fuzz three parameters in a request with a wordlist containing 100 words, how many requests would Burp Suite need to send to complete the attack? 300

> How many sets of payloads will Sniper accept for conducting an attack? 1

Task 7 - Battering Ram

The Battering ram attack type in Burp Suite Intruder differs from Sniper in that it places the same payload in every position simultaneously, rather than substituting each payload into each position in turn.

As a hypothetical question: You need to perform a Battering ram Intruder attack on the example request above. If you have a wordlist with two words in it (admin and Guest) and the positions in the request template look like this: username=§pentester§&password=§Expl01ted§

> What would the body parameters of the first request that Burp Suite sends be? username=admin&password=admin

Task 8 - Pitchfork

The Pitchfork attack type in Burp Suite Intruder is similar to having multiple Sniper attacks running simultaneously. While Sniper uses one payload set to test all positions simultaneously, Pitchfork utilises one payload set per position (up to a maximum of 20) and iterates through them all simultaneously.

> What is the maximum number of payload sets we can load into Intruder in Pitchfork mode? 20

Task 9 - Cluster Bomb

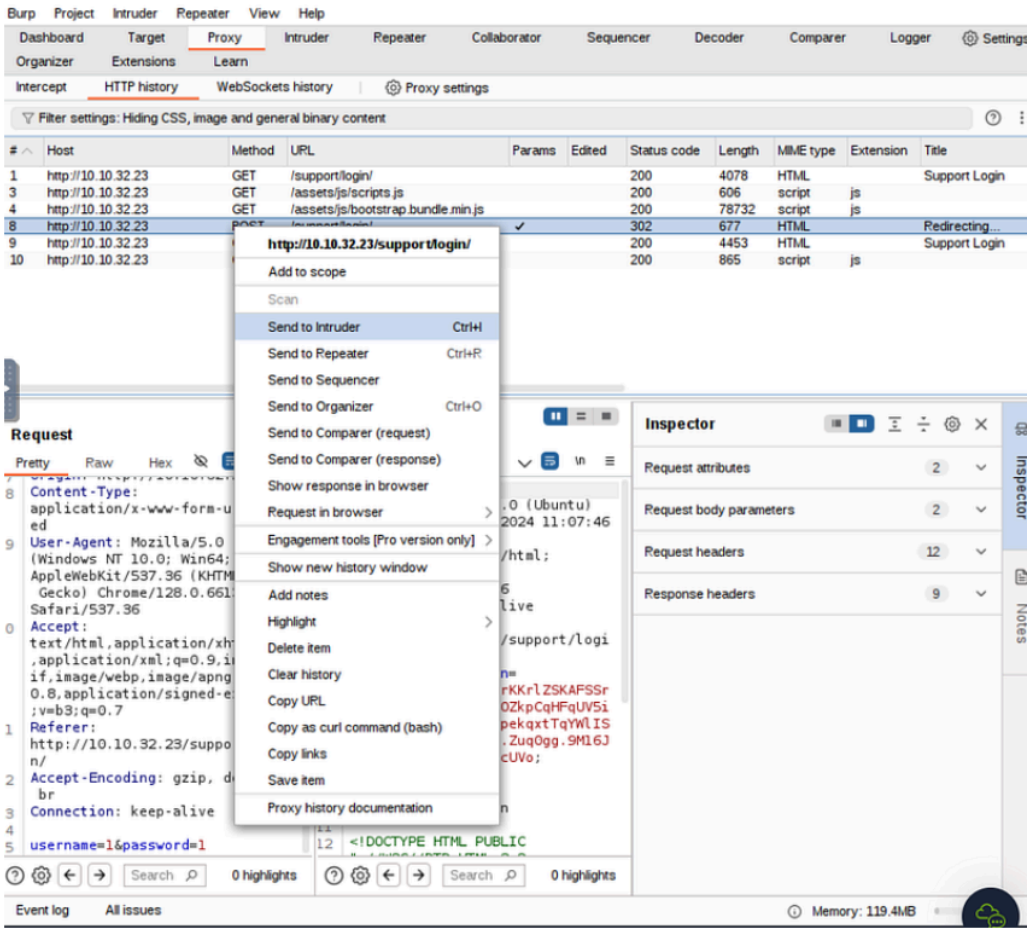
The Cluster bomb attack type in Burp Suite Intruder allows us to choose multiple payload sets, one per position (up to a maximum of 20). Unlike Pitchfork, where all payload sets are tested simultaneously, Cluster bomb iterates through each payload set individually, ensuring that every possible combination of payloads is tested.

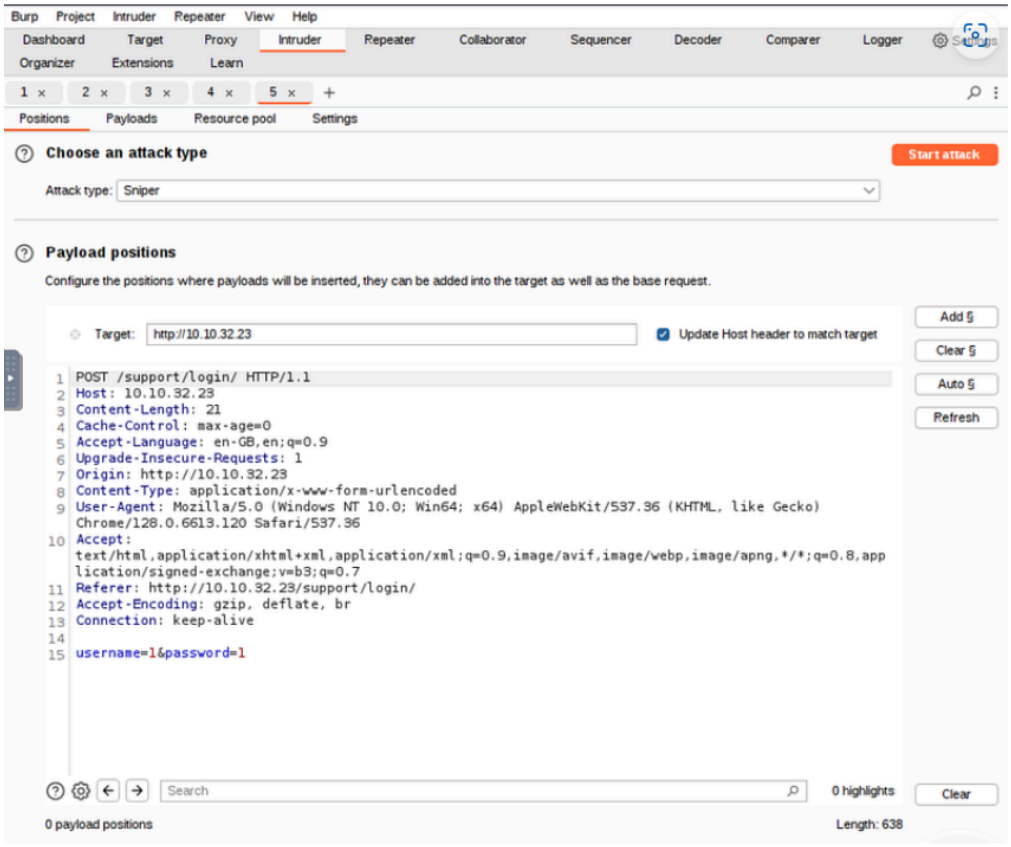
> We have three payload sets. The first set contains 100 lines, the second contains 2 lines, and the third contains 30 lines. How many requests will Intruder make using these payload sets in a Cluster bomb attack? 6000

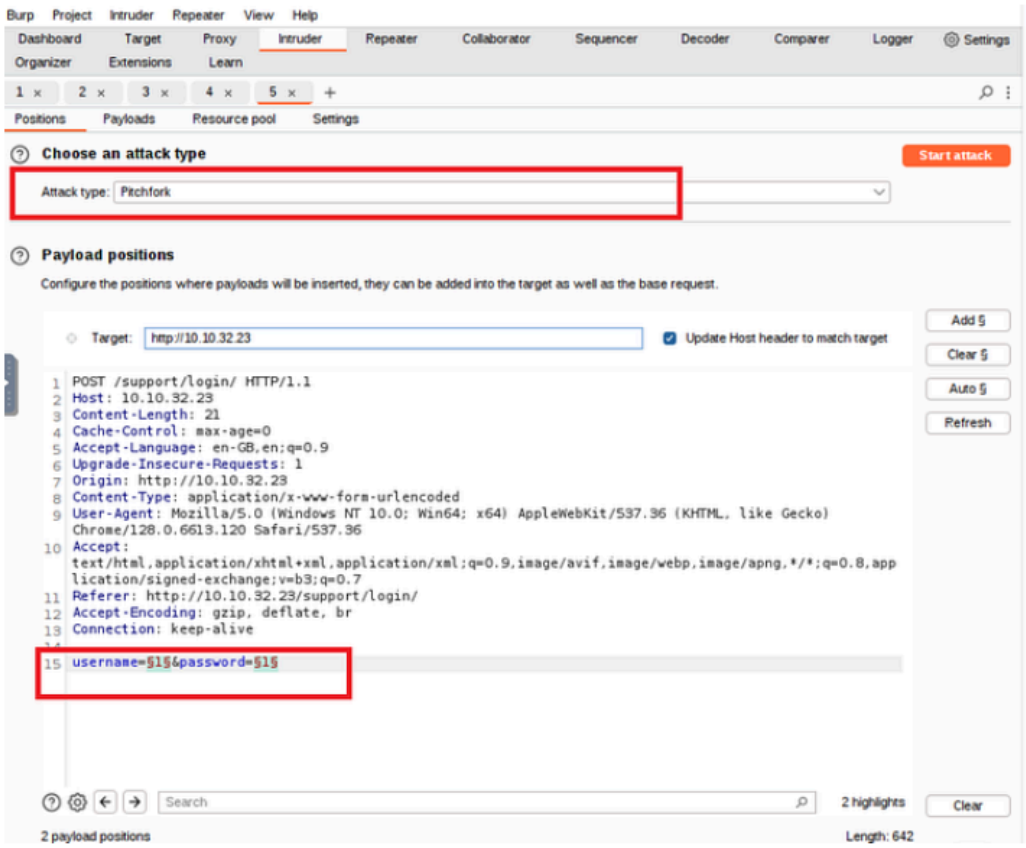
Task 10 - Practical Example

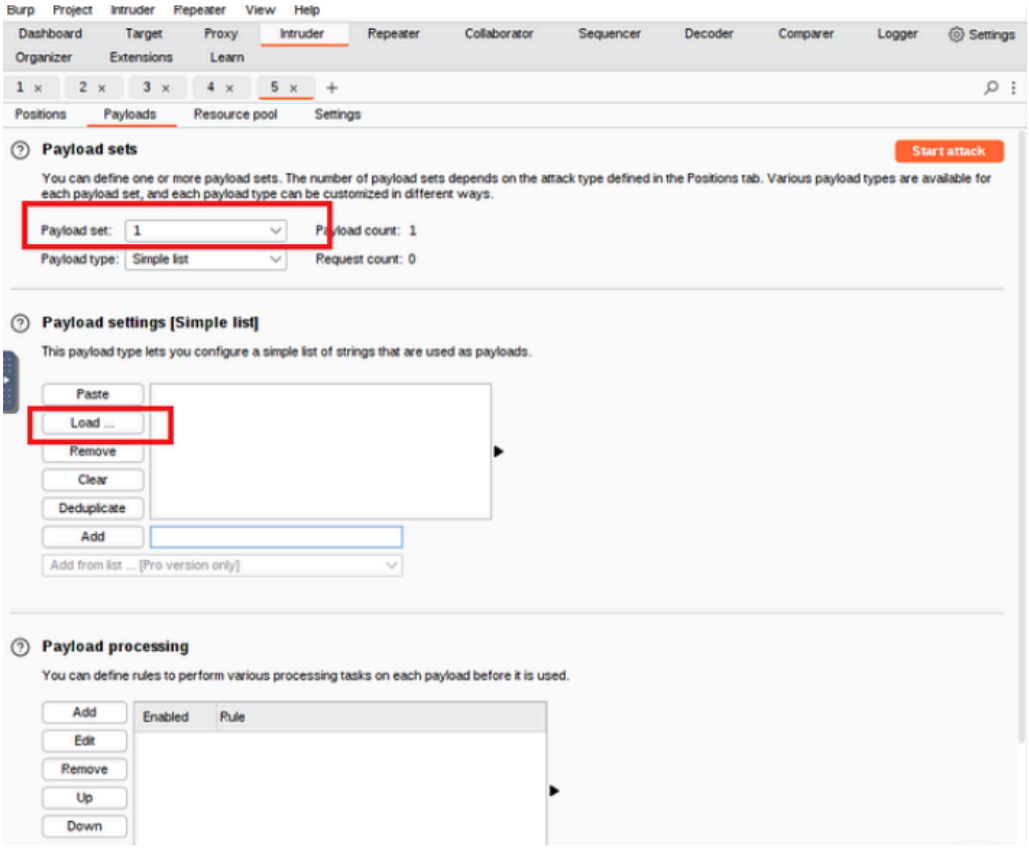
To put our theoretical knowledge into practice, we will attempt to gain access to the support portal located at http://MACHINE_IP/support/login. This portal follows

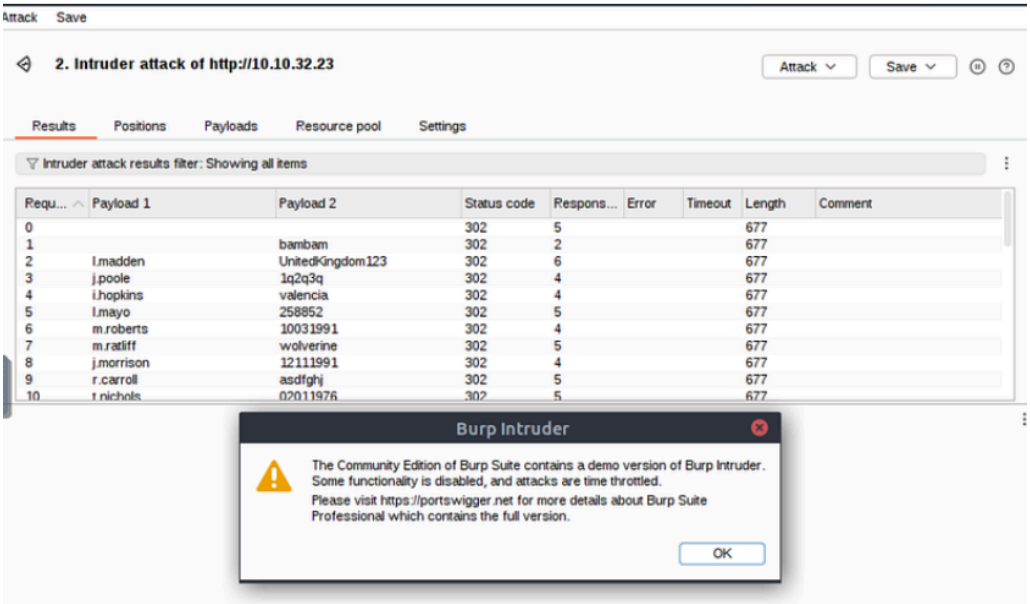
a typical login structure, and upon inspecting its source code,




Burp Project Intruder Repeater View Help
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Settings
Organizer Extensions Learn
1 × 2 × 3 × 4 × 5 ×
Positions Payloads Resource pool Settings
Choose an attack type
Start attack
Attack type: Sniper
Payload positions
Configure the positions where payloads will be inserted, they can be added into the target as well as the base request.
Target: http://10.10.32.23
Update Host header to match target
Add §
Clear §
Auto §
Refresh
1 POST /support/login/ HTTP/1.1
2 Host: 10.10.32.23
3 Content-Length: 21
4 Cache-Control: max-age=0
5 Accept-Language: en-GB,en;q=0.9
6 Upgrade-Insecure-Requests: 1
7 Origin: http://10.10.32.23
8 Content-Type: application/x-www-form-urlencoded
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/128.0.6613.120 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Referer: http://10.10.32.23/support/login/
12 Accept-Encoding: gzip, deflate, br
13 Connection: keep-alive
14
15 username=1&password=1
Search
0 highlights
Clear
0 payload positions
Length: 638


Burp Project Intruder Repeater View Help
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Settings
Organizer Extensions Learn
1 × 2 × 3 × 4 × 5 × +
Positions Payloads Resource pool Settings
Choose an attack type
Start attack
Attack type: Pitchfork
Payload positions
Configure the positions where payloads will be inserted, they can be added into the target as well as the base request.
Target: http://10.10.32.23
Update Host header to match target
Add §
Clear §
Auto §
Refresh
1 POST /support/login/ HTTP/1.1
2 Host: 10.10.32.23
3 Content-Length: 21
4 Cache-Control: max-age=0
5 Accept-Language: en-GB,en;q=0.9
6 Upgrade-Insecure-Requests: 1
7 Origin: http://10.10.32.23
8 Content-Type: application/x-www-form-urlencoded
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/128.0.6613.120 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Referer: http://10.10.32.23/support/login/
12 Accept-Encoding: gzip, deflate, br
13 Connection: keep-alive
15 username=§1§&password=§1§
Search
2 highlights
Clear
2 payload positions
Length: 642


Burp Project Intruder Repeater View Help
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Settings
Organizer Extensions Learn
1 × 2 × 3 × 4 × 5 ×
Positions Payloads Resource pool Settings
Payload sets
Start attack
You can define one or more payload sets. The number of payload sets depends on the attack type defined in the Positions tab. Various payload types are available for each payload set, and each payload type can be customized in different ways.
Payload set: 1
Payload count: 1
Payload type: Simple list
Request count: 0
Payload settings [Simple list]
This payload type lets you configure a simple list of strings that are used as payloads.
Paste
Load ...
Remove
Clear
Deduplicate
Add
Add from list ... [Pro version only]
Payload processing
You can define rules to perform various processing tasks on each payload before it is used.
Add
Edit
Remove
Up
Down
Enabled
Rule


Attack Save
2. Intruder attack of http://10.10.32.23
Attack
Save
Results Positions Payloads Resource pool Settings
Intruder attack results filter: Showing all items
Requ... Payload 1 Payload 2 Status code Respons... Error Timeout Length Comment
0 302 5 677
1 bambam 302 2 677
2 l.madden UnitedKingdom123 302 6 677
3 j.poole 1q2q3q 302 4 677
4 i.hopkins valencia 302 4 677
5 l.mayo 258852 302 5 677
6 m.roberts 10031991 302 4 677
7 m.ratliff wolverine 302 5 677
8 j.morrison 12111991 302 4 677
9 r.carroll asdfghj 302 5 677
10 t.nichols 02011976 302 5 677
Burp Intruder
The Community Edition of Burp Suite contains a demo version of Burp Intruder. Some functionality is disabled, and attacks are time throttled.
Please visit https://portswigger.net for more details about Burp Suite Professional which contains the full version.
OK

Tutorial:

Download and Prepare Wordlists, Navigate to http://MACHINE_IP/support/login in your browser.

Send the captured request from the Proxy to Intruder by right-clicking and selecting "Send to Intruder" In the "Positions" sub-tab, ensure that only the username and password parameters are selected.

Set the Attack type to "Pitchfork.” Move to the "Payloads" sub-tab. You will find two payload sets available for the username and password fields.

In the first payload set (for usernames), go to "Payload Options," choose "Load," and select the usernames.txt list. Click the Start Attack button to begin the credential-stuffing attack. A warning about rate-limiting may appear; click OK to proceed. The attack will take a few minutes to complete in Burp Community.

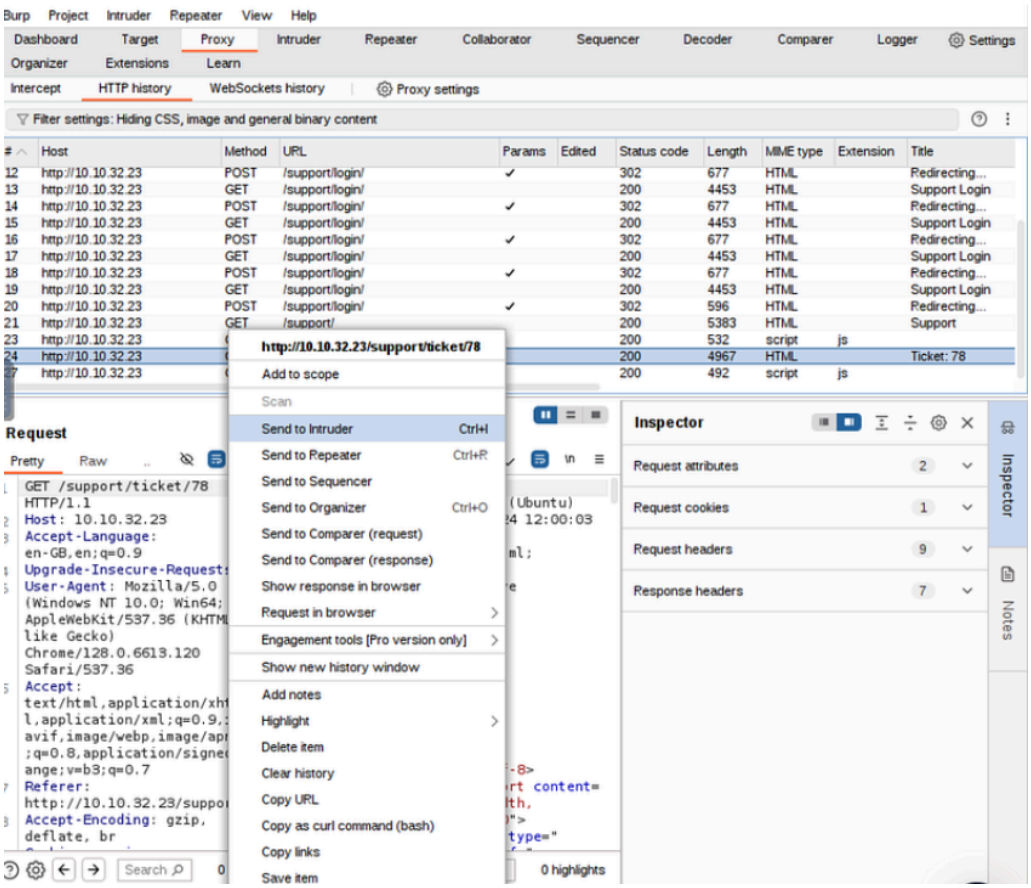
Once the attack starts, a new window will display the results of the requests. However, as Burp sent 100 requests, we need to identify which one(s) were successful.

> What username and password combination indicates a successful login attempt? The answer format is "username:password". m.rivera:letmein1

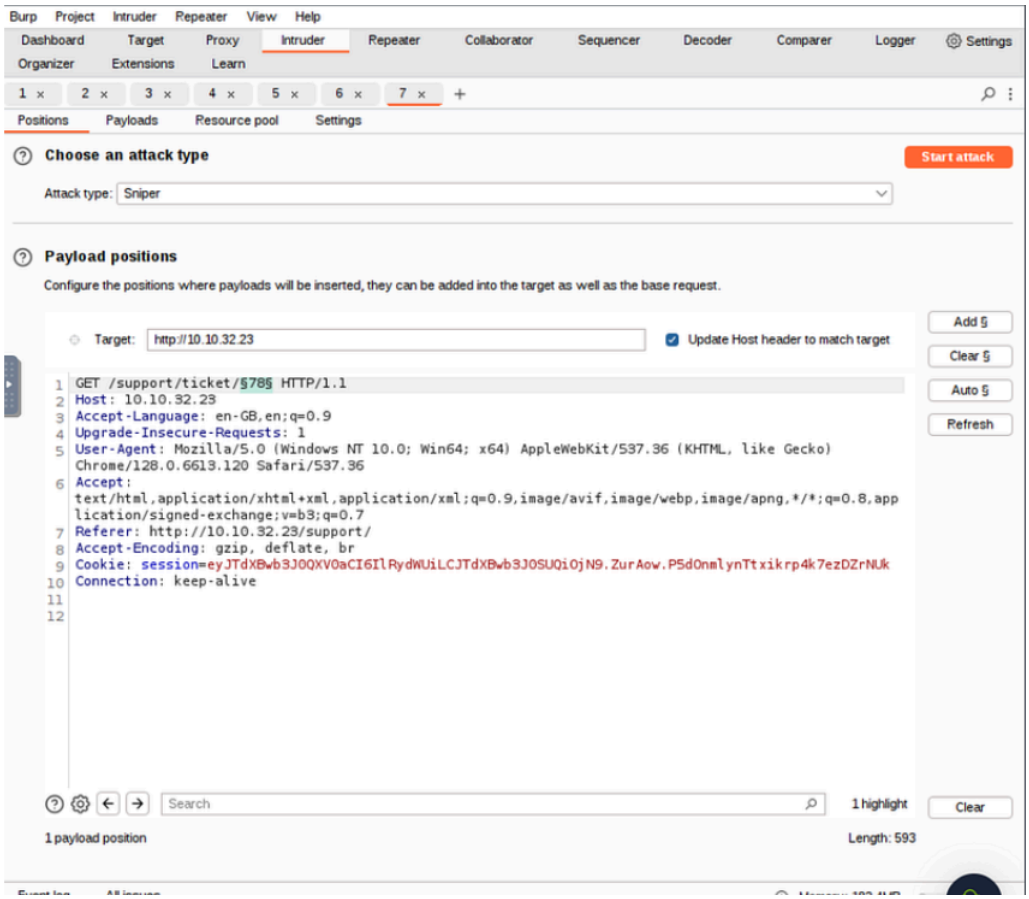
Task 11 - Practical Challenge

The numbering system indicates that the tickets are assigned integer identifiers rather than complex and hard-to-guess IDs. This information is significant because it suggests two possible scenarios:

Access Control: The endpoint may be properly configured to restrict access only to tickets assigned to our current user. In this case, we can only view tickets associated with our account.
IDOR Vulnerability: Alternatively, the endpoint may lack appropriate access controls, leading to a vulnerability known as Insecure Direct Object References (IDOR). If this is the case, we could potentially exploit the system and read all existing tickets, regardless of the assigned user.



#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title
12	http://10.10.32.23	POST	/support/login/	✓		302	677	HTML		Redirecting...
13	http://10.10.32.23	GET	/support/login/			200	4453	HTML		Support Login
14	http://10.10.32.23	POST	/support/login/	✓		302	677	HTML		Redirecting...
15	http://10.10.32.23	GET	/support/login/			200	4453	HTML		Support Login
16	http://10.10.32.23	POST	/support/login/	✓		302	677	HTML		Redirecting...
17	http://10.10.32.23	GET	/support/login/			200	4453	HTML		Support Login
18	http://10.10.32.23	POST	/support/login/	✓		302	677	HTML		Redirecting...
19	http://10.10.32.23	GET	/support/login/			200	4453	HTML		Support Login
20	http://10.10.32.23	POST	/support/login/	✓		302	596	HTML		Redirecting...
21	http://10.10.32.23	GET	/support/			200	5383	HTML		Support
23	http://10.10.32.23					200	532	script	js	
24	http://10.10.32.23					200	4967	HTML		Ticket: 78
27	http://10.10.32.23					200	492	script	js	



> Which attack type is best suited for this task? Sniper

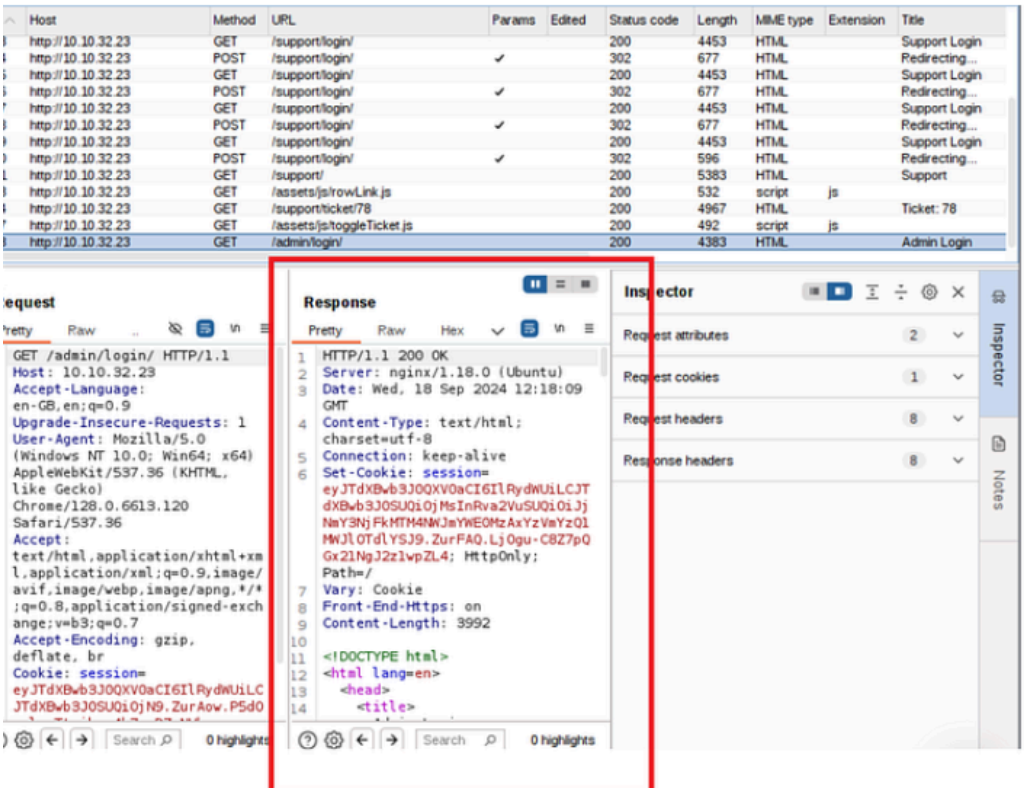
> Either using the Response tab in the Attack Results window or by looking at each successful (i.e. 200 code) request manually in your browser, find the ticket that contains the flag. What is the flag?

THM{MTMxNTg5NTUzMWM0OWRlYzUzMDVjMzJl}

Task 12 - Extra Mile Challenge

Begin by capturing a request to http://MACHINE_IP/admin/login/ and reviewing the response.

Example Response



Tutorial:

1. Navigate to http://MACHINE_IP/admin/login/. Activate Intercept in the Proxy module and attempt to log in. Capture the request and send it to Intruder.

2. Configure the positions the same way as we did for brute-forcing the support login:Set the attack type to "Pitchfork". Clear all predefined positions and select only the username and password form fields. Our macro will handle the other two positions.

3.Now switch over to the Payloads tab and load in the same username and password wordlists we used for the support login attack. Up until this point, we have configured Intruder in almost the same way as our previous credential stuffing attack; this is where things start to get more complicated.

4. With the username and password parameters handled, we now need to find a way to grab the ever-changing loginToken and session cookie. Unfortunately, "recursive grep" won't work here due to the redirect response, so we can't do this

entirely within Intruder – we will need to build a macro. Macros allow us to perform the same set of actions repeatedly. In this case, we simply want to send a GET request to /admin/login/. Fortunately, setting this up is a straightforward process.

Switch over to the main "Settings" tab at the top-right of Burp.
Click on the "Sessions" category.
Scroll down to the bottom of the category to the "Macros" section and click the Add button.
The menu that appears will show us our request history. If there isn't a GET request to http://MACHINE_IP/admin/login/ in the list already, navigate to this location in your browser, and you should see a suitable request appear in the list.
With the request selected, click OK.
Finally, give the macro a suitable name, then click OK again to finish the process.

5.Now that we have a macro defined, we need to set Session Handling rules that define how the macro should be used. Still in the "Sessions" category of the main settings, scroll up to the "Session Handling Rules" section and choose to Add a new rule.

6. Now we need to switch back over to the Details tab and look at the "Rule Actions" section. Click the Add button – this will cause a dropdown menu to appear with a list of actions we can add.
Select "Run a Macro" from this list. In the new window that appears, select the macro we created earlier.

As it stands, this macro will now overwrite all of the parameters in our Intruder requests before we send them; this is great, as it means that we will get the loginTokens and session cookies added straight into our requests. That said, we should restrict which parameters and cookies are being updated before we start our attack:

Select "Update only the following parameters and headers", then click the Edit button next to the input box below the radio button.
In the "Enter a new item" text field, type "loginToken". Press Add, then Close.
Select "Update only the following cookies", then click the relevant Edit button.
Enter "session" in the "Enter a new item" text field. Press Add, then Close.
Finally, press OK to confirm our action.

7. You should now have a macro defined that will substitute in the CSRF token and session cookie. All that's left to do is switch back to Intruder and start the attack!

Note: You should be getting 302 status code responses for every request in this attack. If you see 403 errors, then your macro is not working properly.

8. As with the support login credential stuffing attack we carried out, the response codes here are all the same (302 Redirects). Once again, order your responses by length to find the valid credentials. Your results won't be quite as clear-cut as last time – you will see quite a few different response lengths: however, the response that indicates a successful login should still stand out as being significantly shorter.

9. Use the credentials you just found to log in (you may need to refresh the login page before entering the credentials).

Task 13 - Conclusion

By now, you should have a solid understanding of how to effectively utilize Intruder to automate requests and perform various types of attacks.

4. Burp Suite: Other Modules

Task 1: Introduction

They facilitate operations with encoded text, enable comparison of data sets, allow the analysis of randomness within captured tokens, and help you store and annotate copies of HTTP messages that you may want to revisit later.

Task 2: Decoder

The Decoder module of Burp Suite gives user data manipulation capabilities. As implied by its name, it not only decodes data intercepted during an attack but also provides the function to encode our own data, prepping it for transmission to the target.



> Question 1: Which feature attempts auto-decode of the input? Smart decode

Task 3: Decoder (Encoding/Decoding)

Plain: This refers to the raw text before any transformations are applied.

URL: URL encoding is utilized to ensure the safe transfer of data in the URL of a web request.

HTML: HTML Entities encoding replaces special characters with an ampersand (&), followed by either a hexadecimal number or a reference to the character being escaped, and ending with a semicolon (;)

Base64: Base64, a commonly used encoding method, converts any data into an ASCII-compatible format.

ASCII Hex: This option transitions data between ASCII and hexadecimal representations.

Gzip: Gzip compresses data, reducing file and page sizes before browser transmission.

Hex Format
While inputting data in ASCII format is beneficial, there are times when byte-by-byte input editing is necessary.

Smart Decode
Lastly, we have the Smart decode option. This feature tries to auto-decode encoded text.

> Question 2: Base64 encode the phrase: Let’s Start Simple. What is the base64 encoded version of this text? Answer: TGV0J3MgU3RhcnQgU2ltcGxl

> Question 3: URL Decode this data: %4e%65%78%74%3a%20%44%65%63%6f%64%69%6e%67. What is the plaintext returned? Answer: Next:Decoding

> Question 4: Use Smart decode to decode this data: %34%37. What is the decoded text? Answer: 47

> Question 5: Encode this phrase: Encoding Challenge. Start with base64 encoding. Take the output of this and convert it into ASCII Hex. Finally, encode the hex string into octal. What is the final string? Answer: 24034214a720270024142d5413574712322502535 52c1162d1206c

Task 4: Decoder (Hashing)

Hash In addition to its Encoding/Decoding functionality, Decoder also offers the ability to generate hashsums for our data. The MD5 algorithm is deprecated and should not be used for contemporary applications.

> Question 6: Using Decoder, what is the SHA-256 hashsum of the phrase: Let's get Hashing!? Convert this into an ASCII Hex string for the answer to this question.

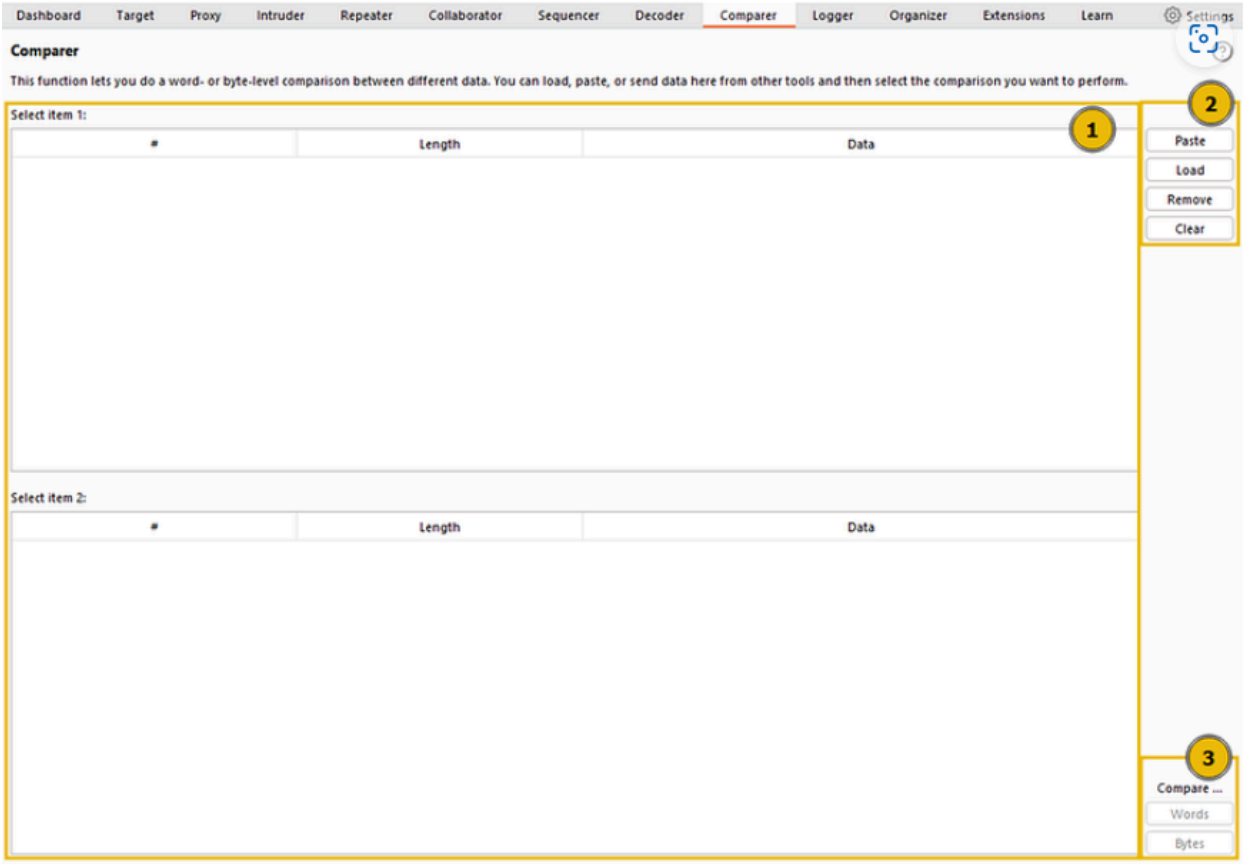
Answer: 6b72350e719a8ef5af560830164b13596cb582757437e21d1879502072238abe

> Question 7: Generate an MD4 hashsum of the phrase: Insecure Algorithms. Encode this as base64 (not ASCII Hex) before submitting.

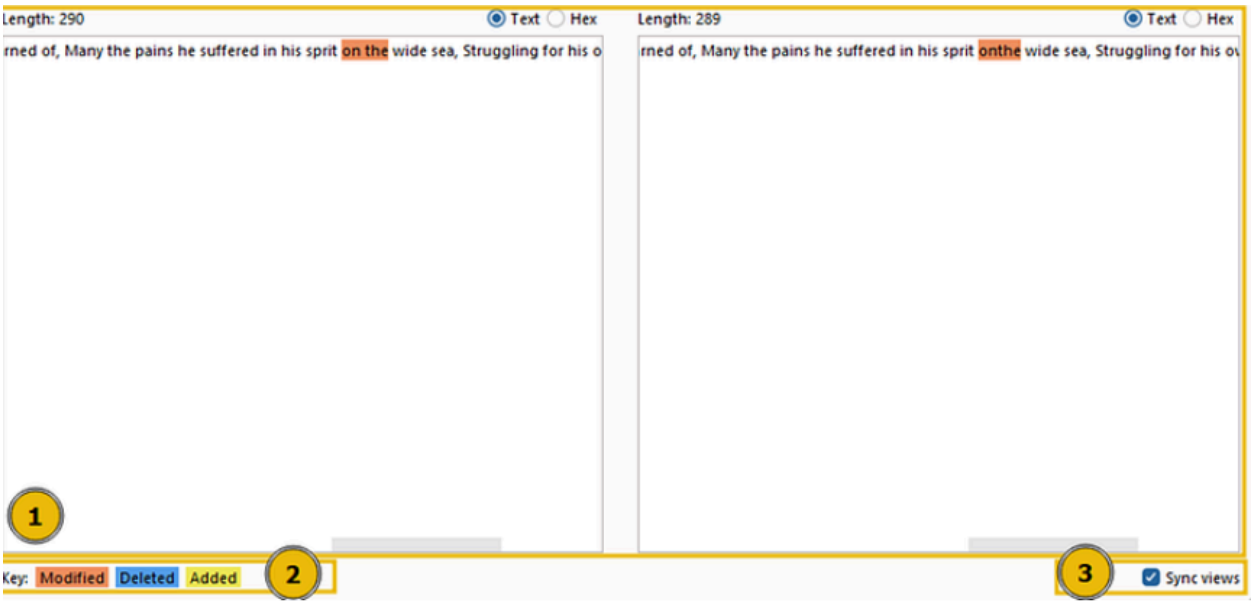
Answer: TcV4QGZZN7y7IwYFRMMoeA==

Task 5: Comparer

Comparer, as the name implies, lets us compare two pieces of data, either by ASCII words or by bytes.



Just like most Burp Suite modules, we can also load data into Comparer from other modules by right-clicking and choosing Send to Comparer. Once we've added at least 2 datasets to compare and press on either Words or Bytes, a pop-up window shows us the comparison:



This window also has three distinct sections:

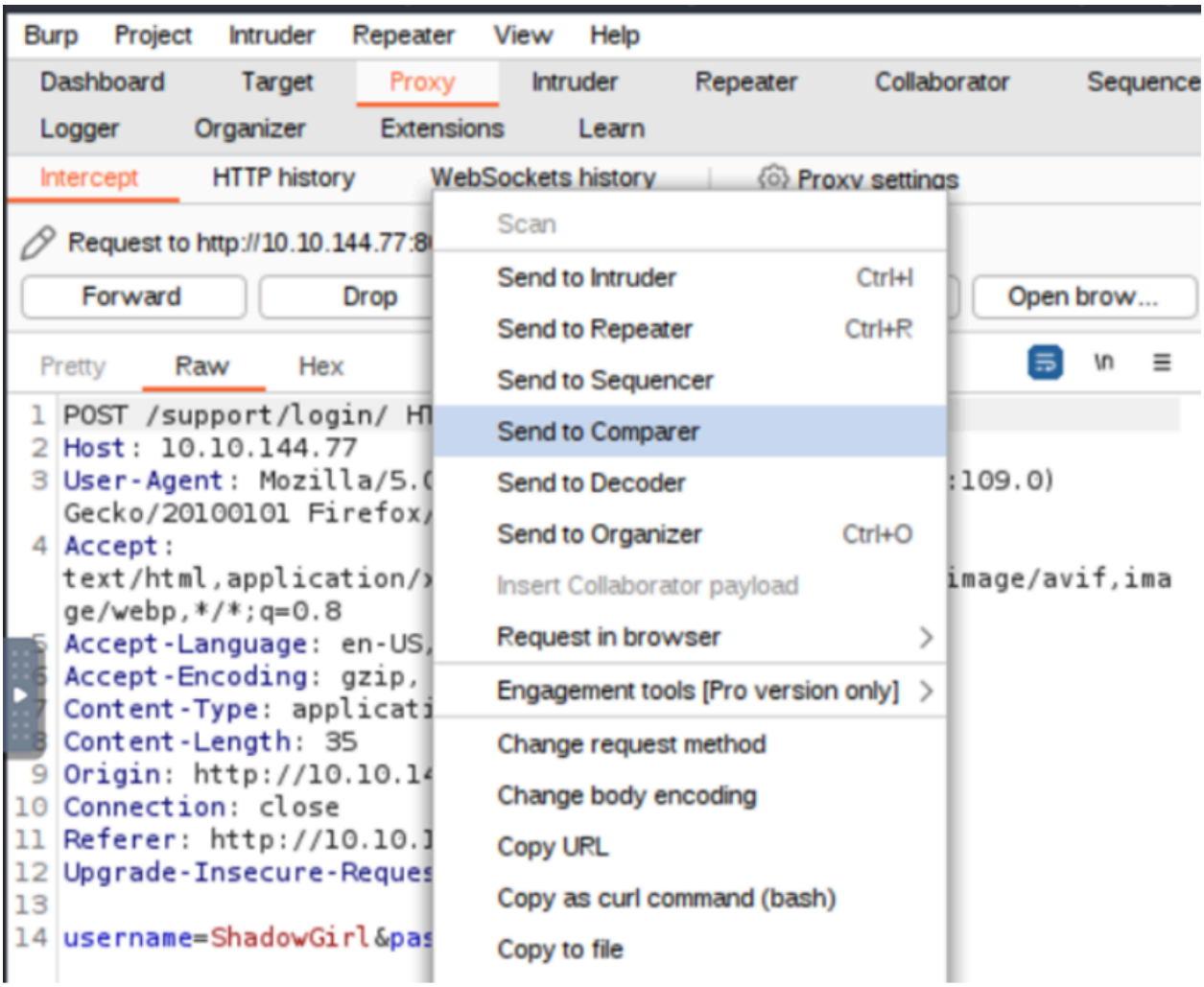
1. The compared data occupies most of the window; it can be viewed in either text or hex format. The initial format depends on whether we chose to compare by words or bytes in the previous window, but this can be overridden by using the buttons above the comparison boxes.
2. The comparison key is at the bottom left, showing which colors represent modified, deleted, and added data between the two datasets.
3. The **Sync views** checkbox is at the bottom right of the window. When selected, it ensures that both sets of data will sync formats. In other words, if you change one of them into Hex view, the other will adjust to match.

The window title displays the total number of differences found.

Task 6: Comparer (Example)

There are many situations where being able to quickly compare two (potentially very large) pieces of data can come in handy.


Burp Project Intruder Repeater View Help
Dashboard Target Proxy Intruder Repeater Collaborator Sequence
Logger Organizer Extensions Learn
Intercept HTTP history WebSockets history Proxy settings
Request to http://10.10.144.77:80
Forward Drop Intercept is ... Action Open brow...
Pretty Raw Hex \n
1 GET /support/login/ HTTP/1.1
2 Host: 10.10.144.77
3 User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/109.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate
7 Connection: close
8 Upgrade-Insecure-Requests: 1
9
10



Practical Example

Navigate to http://MACHINE_IP/support/login Try to log in with an invalid username and password – capture the request in the Burp Proxy.

Send the request to Repeater with Ctrl + R (or Mac equivalent) or by right-clicking on the request in the Proxy module and choosing Send to Repeater.

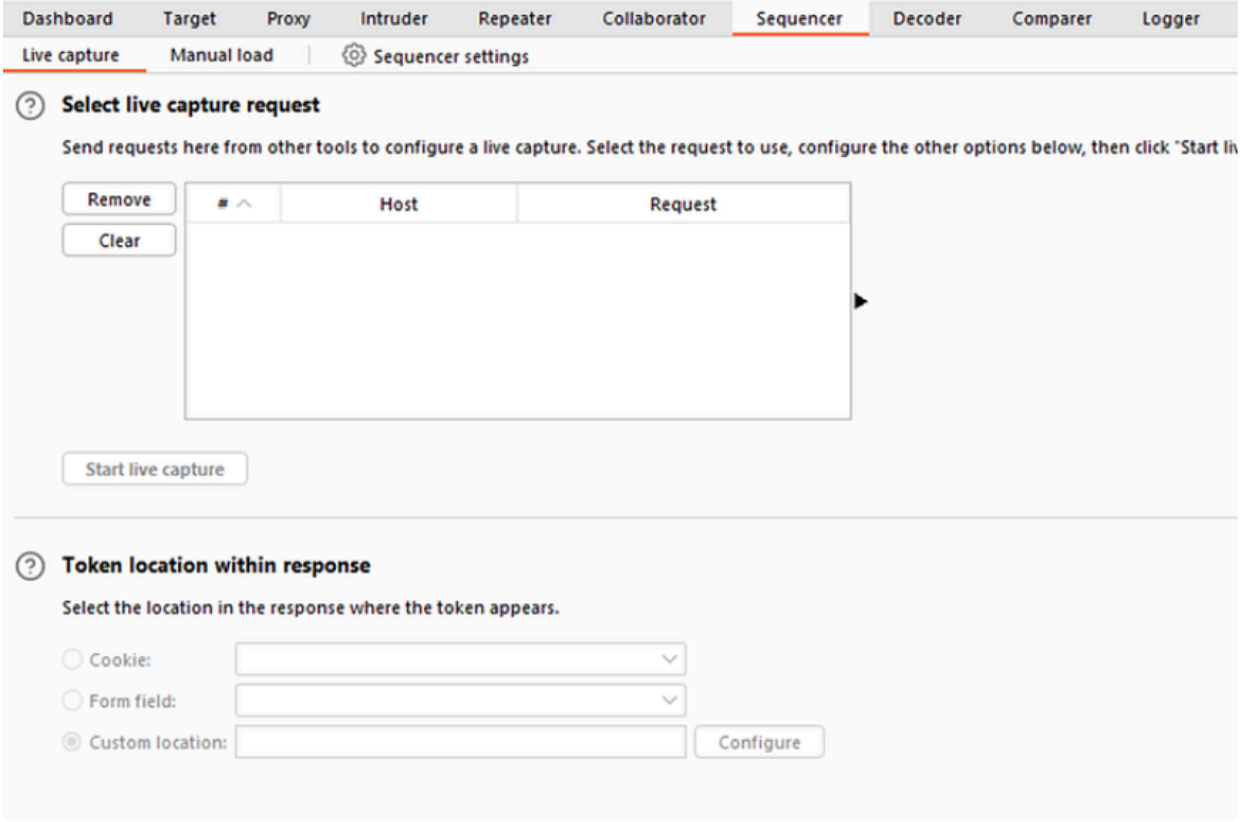
Send the request, then right-click on the response and choose Send to Comparer.

In the Repeater tab, change the credentials to:

Username: support_admin
Password: w58ySK4W
Send the request again, then pass the new response to Comparer.

Task 7: Sequencer (Overview)

Sequencer allows us to evaluate the entropy, or randomness, of “tokens”. Tokens are strings used to identify something and should ideally be generated in a cryptographically secure manner. These tokens could be session cookies or Cross-Site Request Forgery (CSRF) tokens used to protect form submissions.

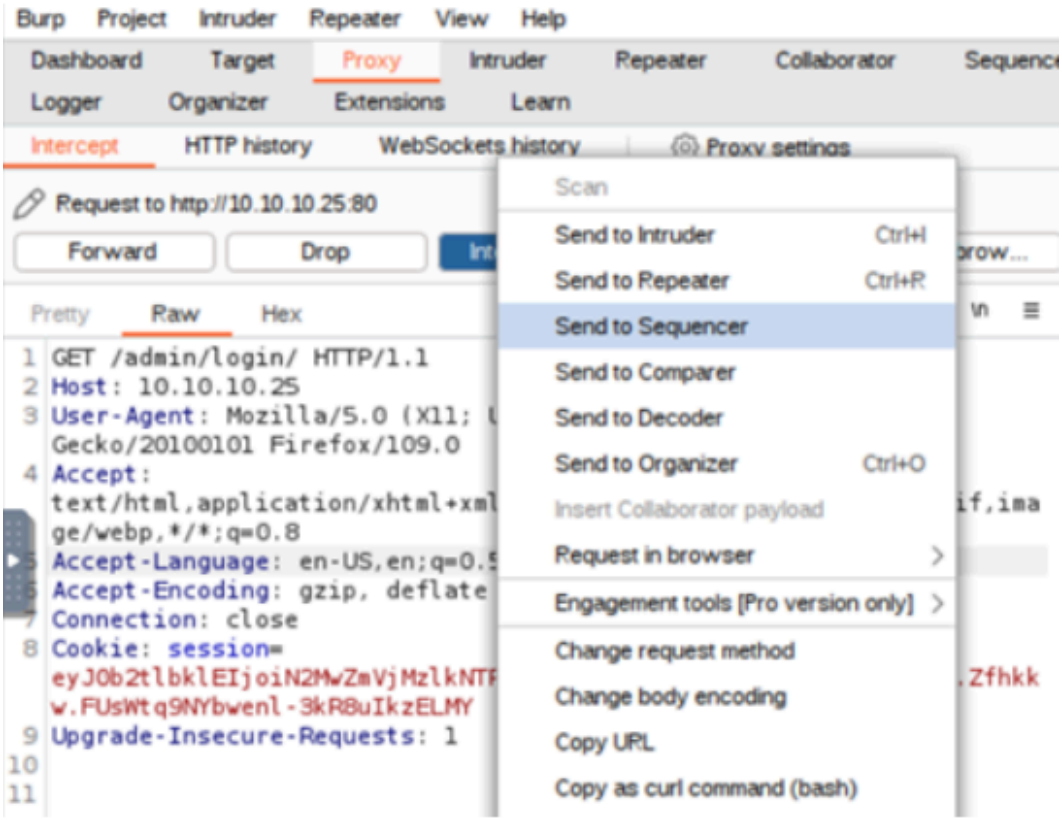


Live Capture: This is the more common method and is the default sub-tab for Sequencer. Live capture lets us pass a request that will generate a token to Sequencer for analysis.

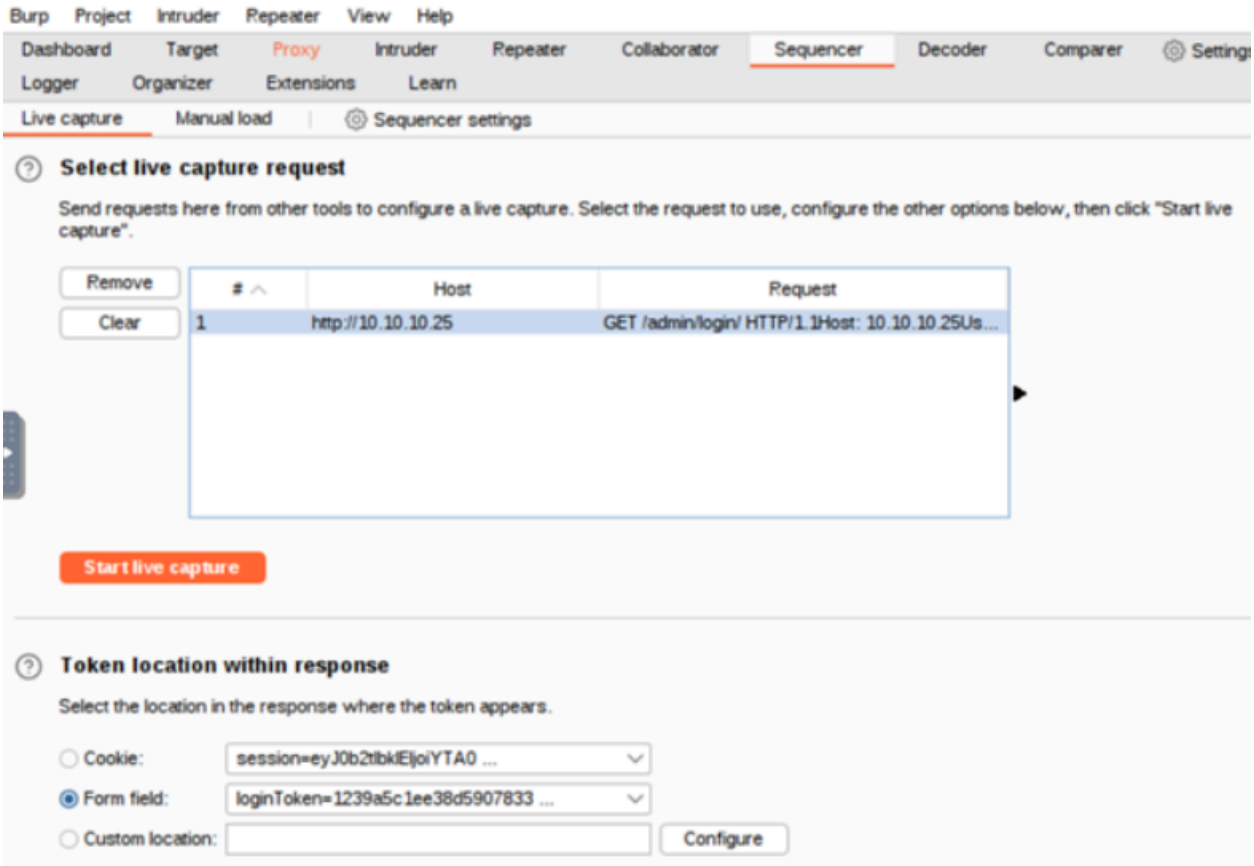
Manual Load: This allows us to load a list of pre-generated token samples directly into Sequencer for analysis.

> What does Sequencer allow us to evaluate? Entropy

Task 8: Sequencer (Live Capture)



In the “Token Location Within Response” section, we can select between Cookie, Form field, and Custom location. In this situation, we can safely leave all other options at their default values. So, click on the Start live capture button.

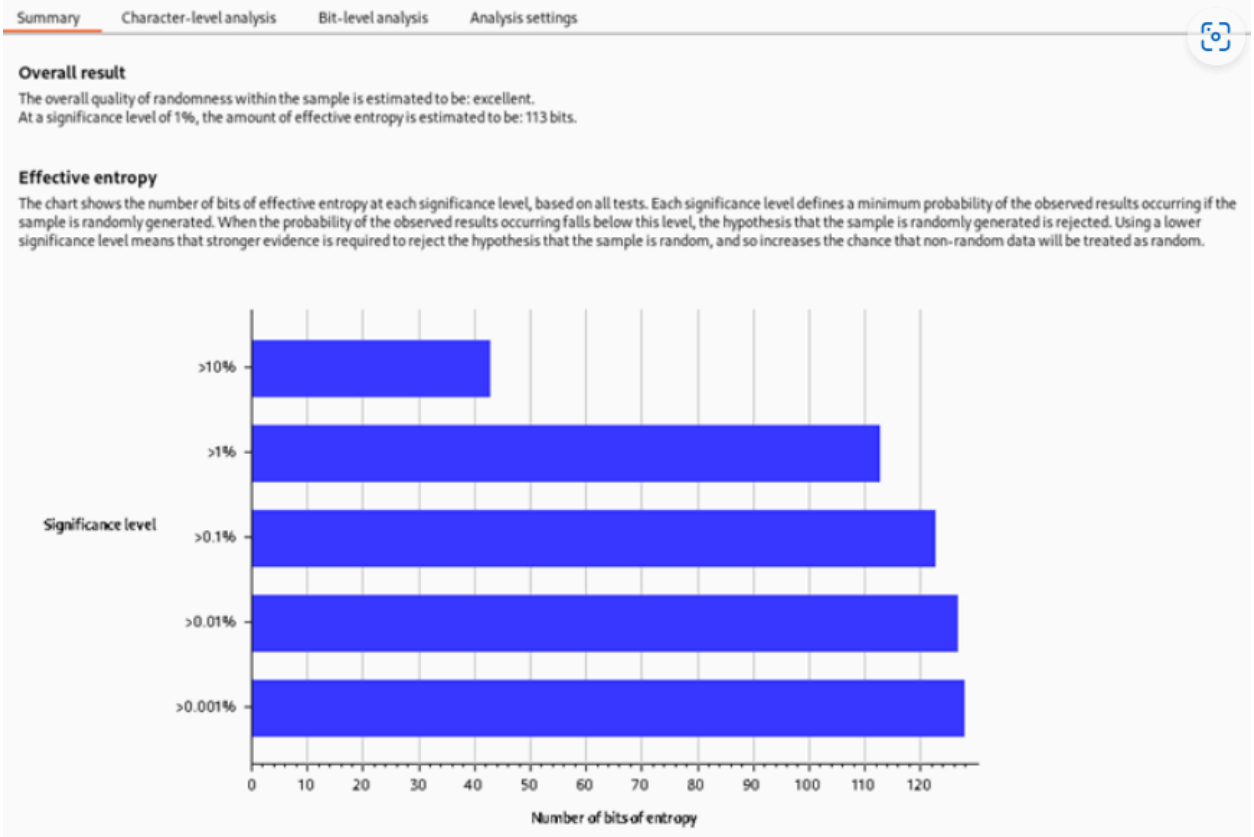


Once around 10,000 tokens are captured, click on **Pause** and then select the **Analyze now button.** It's important to note that we could have also chosen to **Stop** the capture. However, by opting to pause, we keep the option to resume the capture later if the report doesn't have enough samples to accurately calculate the token's entropy.

> What is the overall quality of randomness estimated to be? excellent

Task 9: Sequencer (Analysis)

The generated entropy analysis report is split into four primary sections. The first of these is the **Summary** of the results. The summary gives us the following:



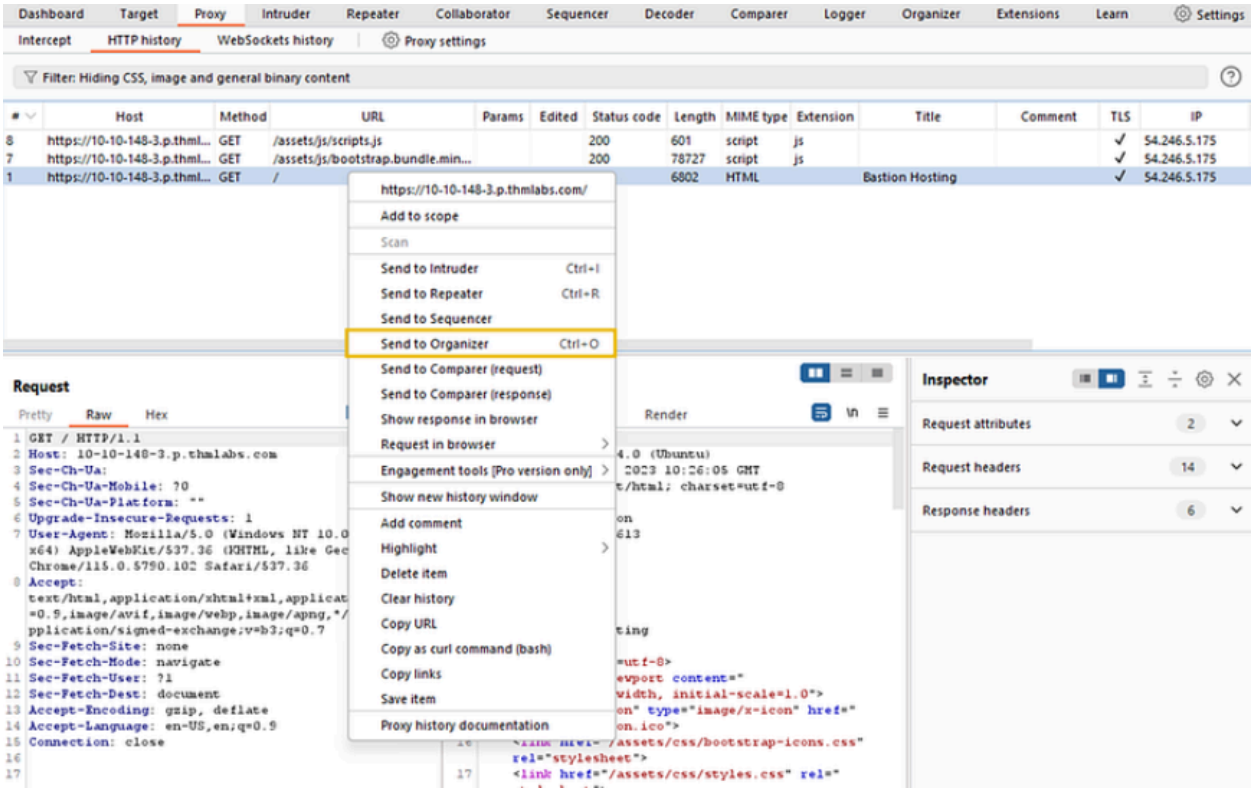
Overall result: This gives a broad assessment of the security of the token generation mechanism.
Effective entropy: This measures the randomness of the tokens.
Reliability: The significance level of 1% implies that there is 99% confidence in the accuracy of the results.

Sample: This provides details about the token samples analyzed during the entropy testing process, including the number of tokens and their characteristics

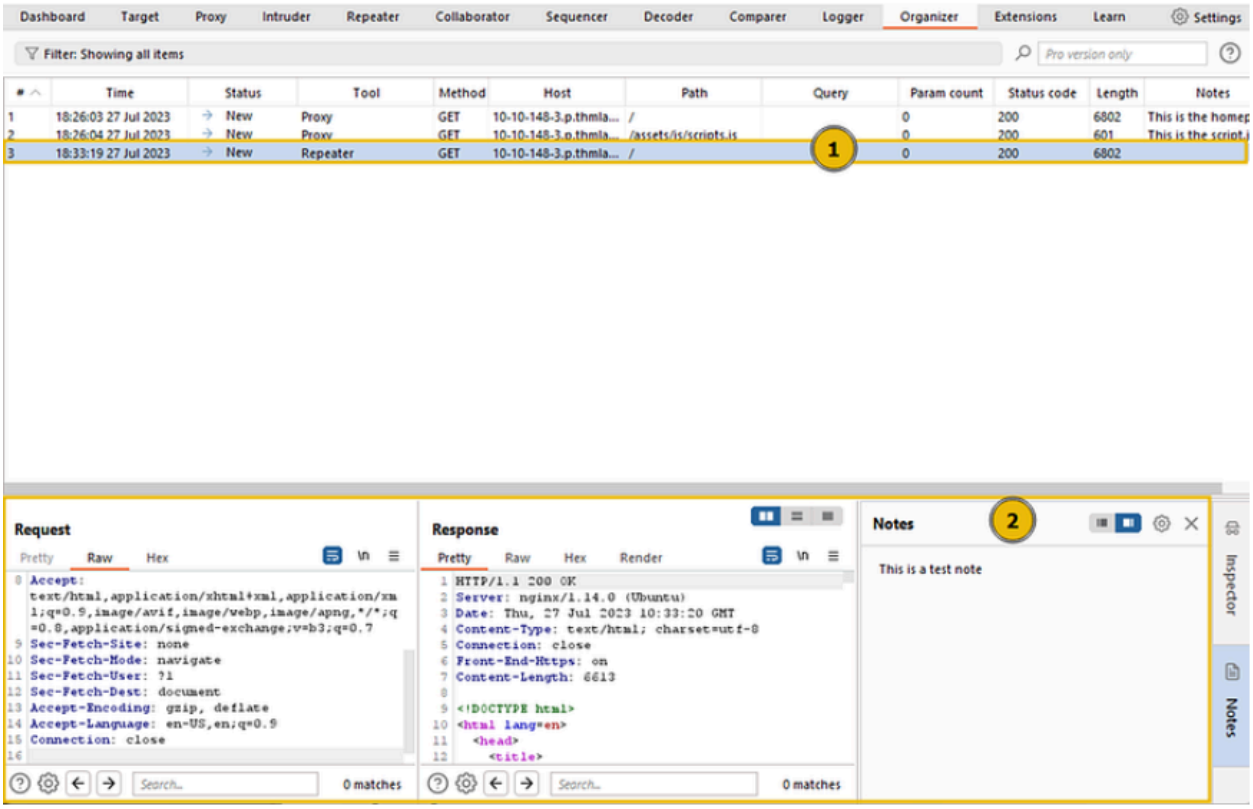
Task 10: Organizer

The Organizer module of Burp Suite is designed to help you store and annotate copies of HTTP requests that you may want to revisit later. This tool can be particularly useful for organizing your penetration testing workflow. You can send HTTP requests to Burp Organizer from other Burp Modules such as Proxy or Repeater. You can do this by right-clicking the request and selecting Send to Organizer or using the default hotkey Ctrl + O. Each HTTP request that you send

to Organizer is a read-only copy of the original request saved at the point you sent it to Organizer.



Requests are stored in a table, which contains columns such as the request index number, the time the request was made, workflow status, Burp tool that the request was sent from, HTTP method, server hostname, URL file path, URL query string, number of parameters in the request, HTTP status code of the response, length of the response in bytes, and any notes that you have made.



To view the request and response:

1. Click on any Organizer item.
2. The request and response are both read-only. You can search within the request or response, select the request, and then use the search bar below the request.

> Are saved requests read-only? (yea/nay) yea

Task 11: Conclusion

Decoder allows you to encode and decode data, making it easier to read and understand the information being transferred.

Comparer enables you to spot differences between two datasets, which can be pivotal in identifying vulnerabilities or anomalies.

Sequencer helps in performing entropy analysis on tokens, providing insights into the randomness of their generation and, consequently, their security level.

·**Organizer** enables you to store and annotate copies of HTTP requests that you may want to revisit later.

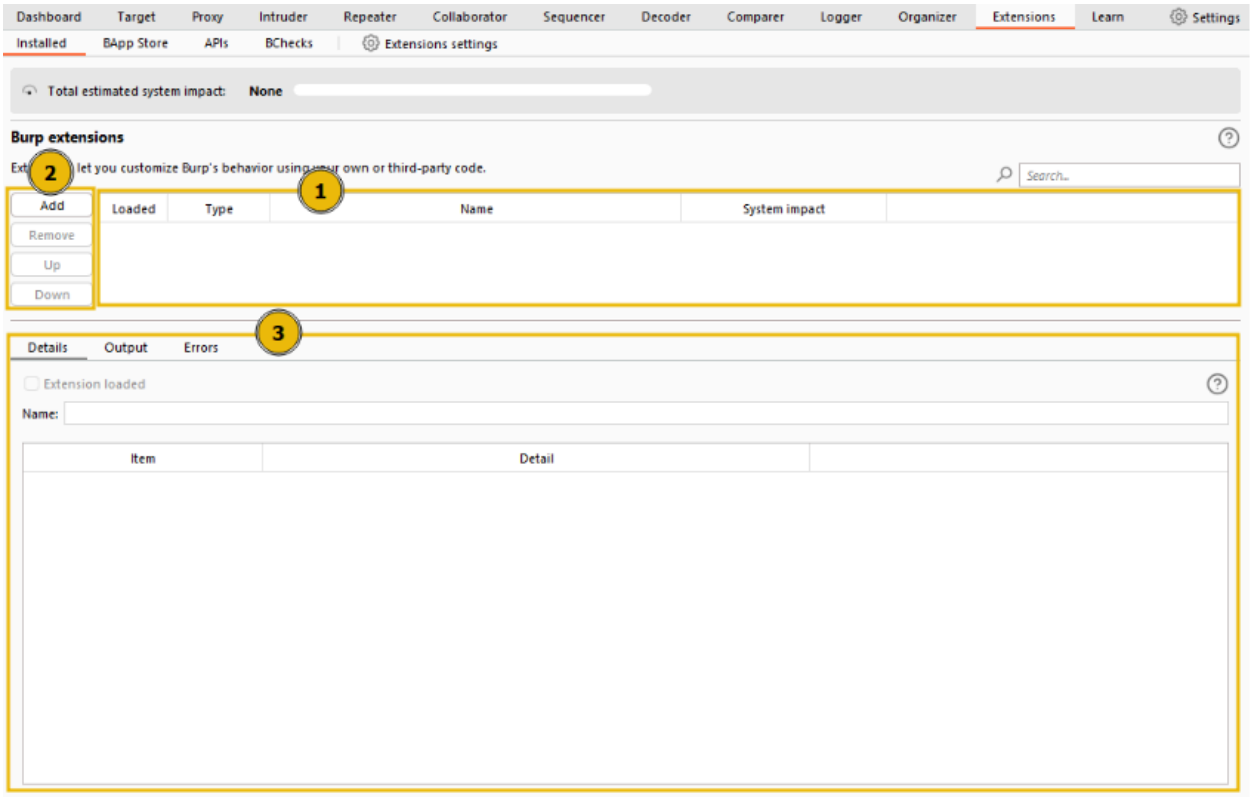
5. Burp Suite: Extensions

Task 1: Introduction

Examined the API documentation and discuss the typical process of adding new modules using the Burp Suite **BApp Store**.

Task 2: The Extensions Interface

The Extensions interface in Burp Suite provides an overview of the extensions loaded into the tool.



Extensions List: The top box displays a list of the extensions that are currently installed in Burp Suite for the current project. It allows you to activate or deactivate individual extensions.

Managing Extensions: On the left side of the Extensions interface, there are options to manage extensions:

Add: You can use this button to install new extensions from files on your disk. These files can be custom-coded modules or modules obtained from external sources that are not available in the official BApp store.
Remove: This button allows you to uninstall selected extensions from Burp Suite.
Up/Down: These buttons control the order in which installed extensions are listed. The order determines the sequence in which extensions are invoked when processing traffic. Extensions are applied in descending order, starting from the top of the list and moving down. The order is essential, especially when dealing with extensions that modify requests, as some may conflict or interfere with others.

Details, Output, and Errors: Towards the bottom of the window, there are sections for the currently selected extension:

Details: This section provides information about the selected extension, such as its name, version, and description.
Output: Extensions can produce output during their execution, and this section displays any relevant output or results.
Errors: If an extension encounters any errors during execution, they will be shown in this section. This can be useful for debugging and troubleshooting extension issues.

In summary, the Extensions interface in Burp Suite allows users to manage and monitor the installed extensions, activate or deactivate them for specific projects, and view important details, output, and errors related to each extension. By using extensions, Burp Suite becomes a powerful and customizable platform for various security testing and web application assessment tasks.

> Are extensions invoked in ascending (A) or descending (D) order? D

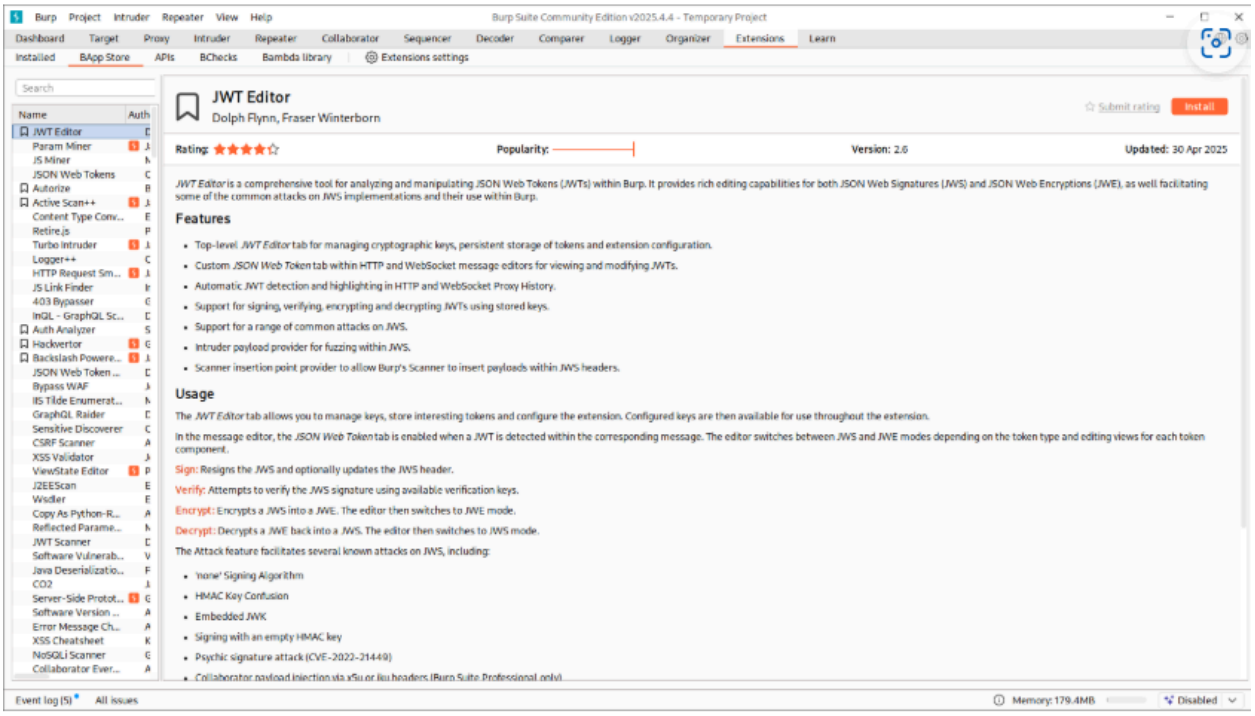
Task 3: The BApp Store

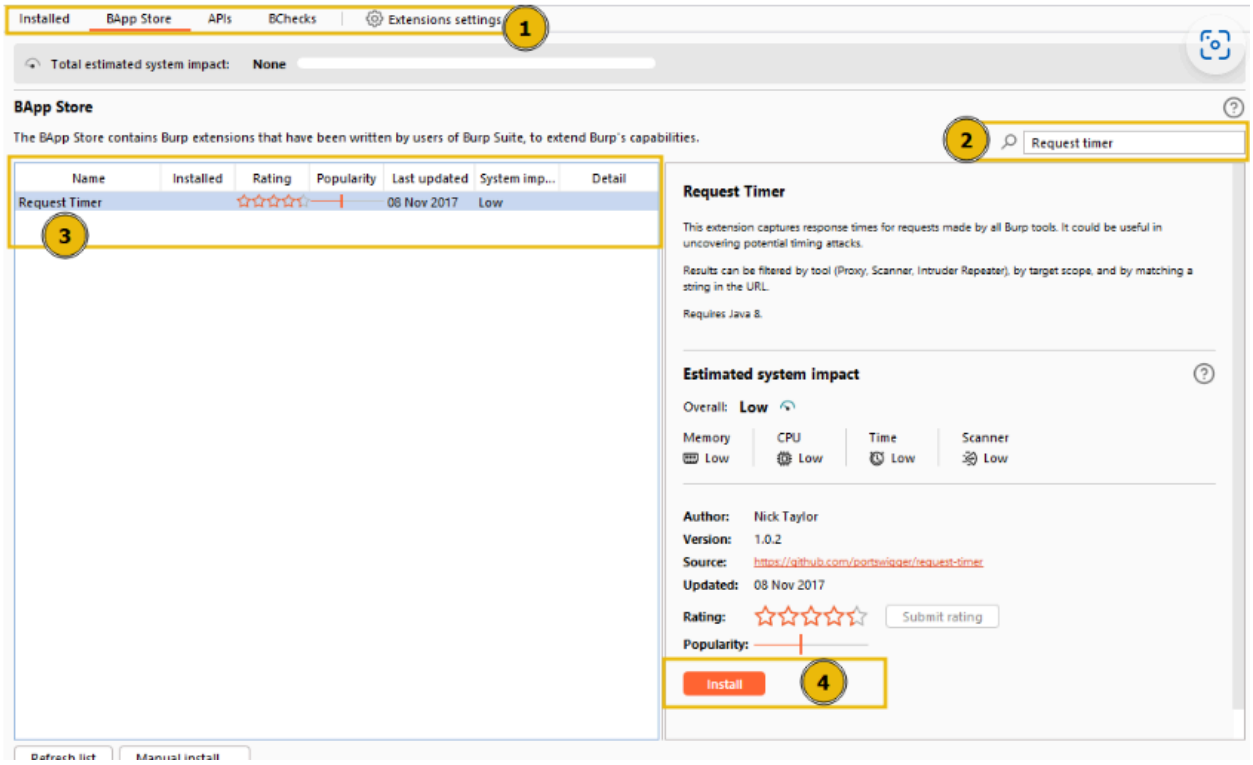
In Burp Suite, the BApp Store (Burp App Store) allows us to easily discover and integrate official extensions seamlessly into the tool. Extensions can be written in various languages, with Java and Python being the most common choices. Java extensions integrate automatically with the Burp Suite framework, while Python

extensions require the Jython interpreter. Follow these steps to install the Request Timer extension from the BApp store:

1. Switch to the **BApp Store** sub-tab in Burp Suite.
2. Use the search function to find **Request Timer**. There should only be one result for this extension.
3. Click on the returned extension to view more details.
4. Click the **Install** button to install the Request Timer extension.

Switch to the **BApp Store** sub-tab in Burp Suite.

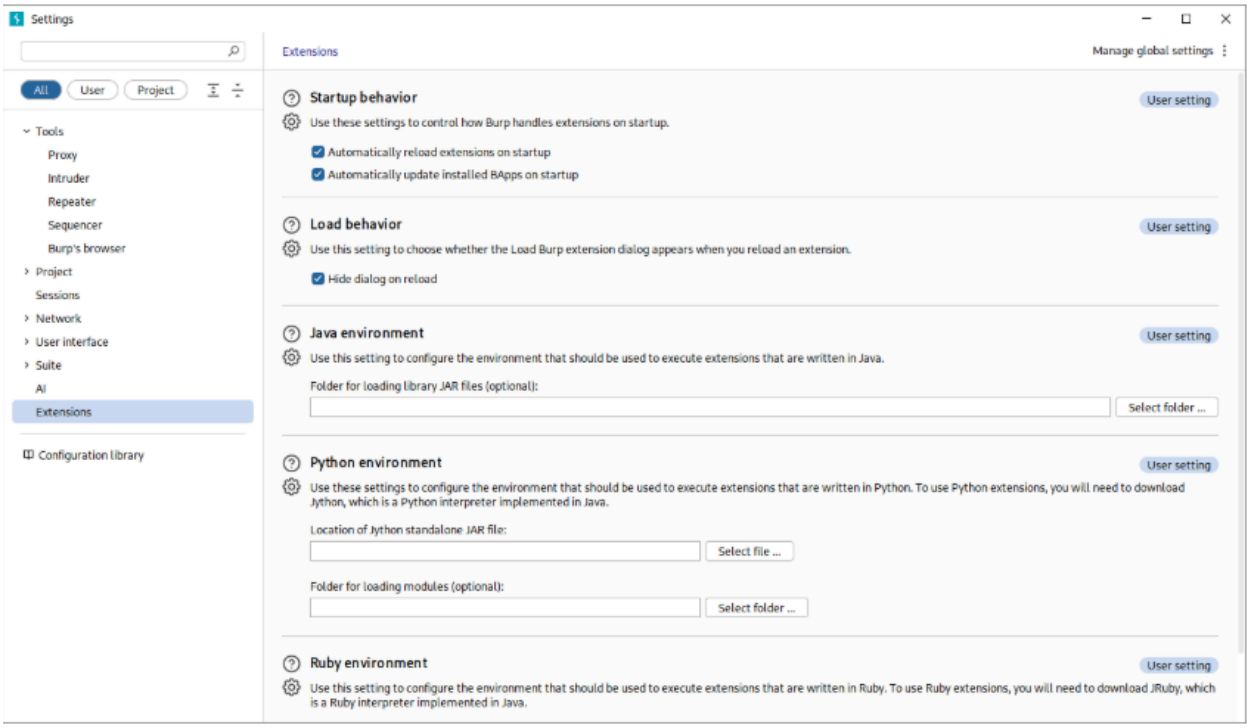


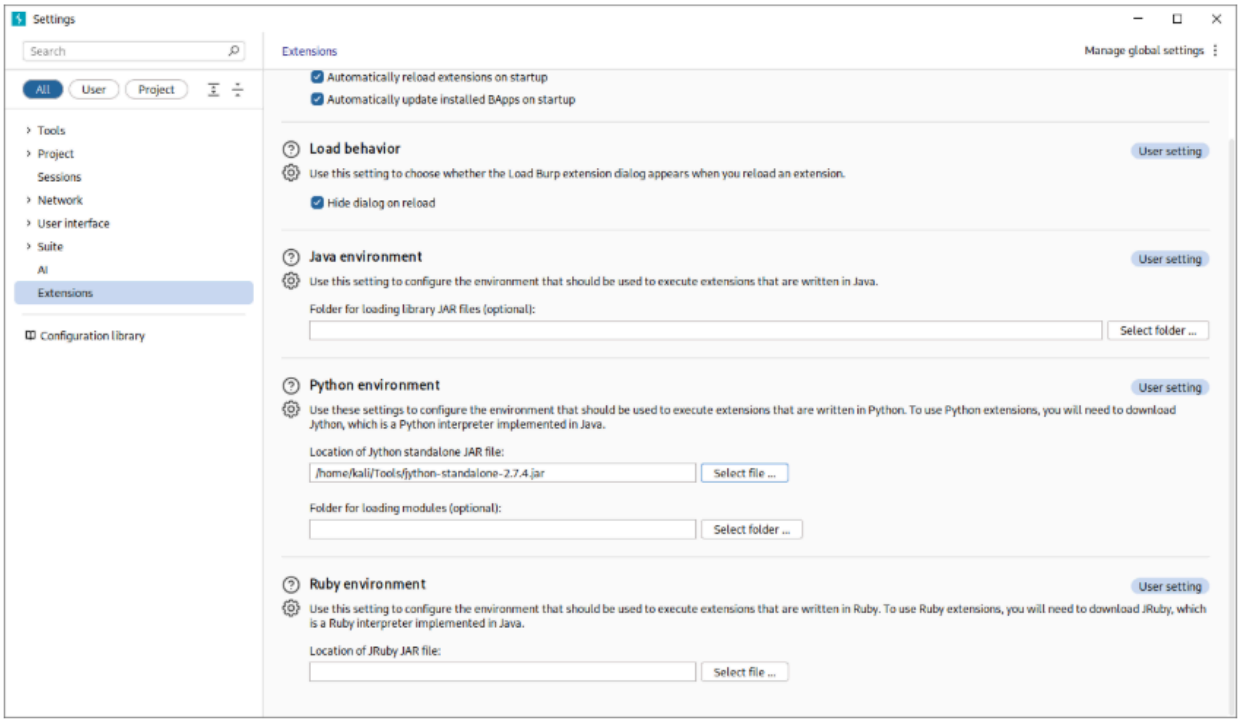


As this installation is simply an example of using the BApp store, we won't cover how to use the Request Timer here. However, I highly recommend switching to the new tab and exploring the extension to understand its functionalities better. The Request Timer can be valuable in various scenarios, especially when assessing web application security and identifying potential time-based vulnerabilities.

Task 4: Jython

To use Python modules in Burp Suite, we need to include the Jython Interpreter JAR file, which is a Java implementation of Python. The Jython Interpreter enables us to run Python-based extensions within Burp Suite. Download Jython JAR: Visit the Jython website and download the standalone JAR archive. Look for the Jython Standalone option. Save the JAR file to a location on your disk. Configure Jython in Burp Suite: Open Burp Suite and switch to the Extensions module. Then, go to the Extensions settings sub-tab. Set Jython JAR Location: In the "Location of Jython standalone JAR file" field, set the path to the downloaded Jython JAR file.

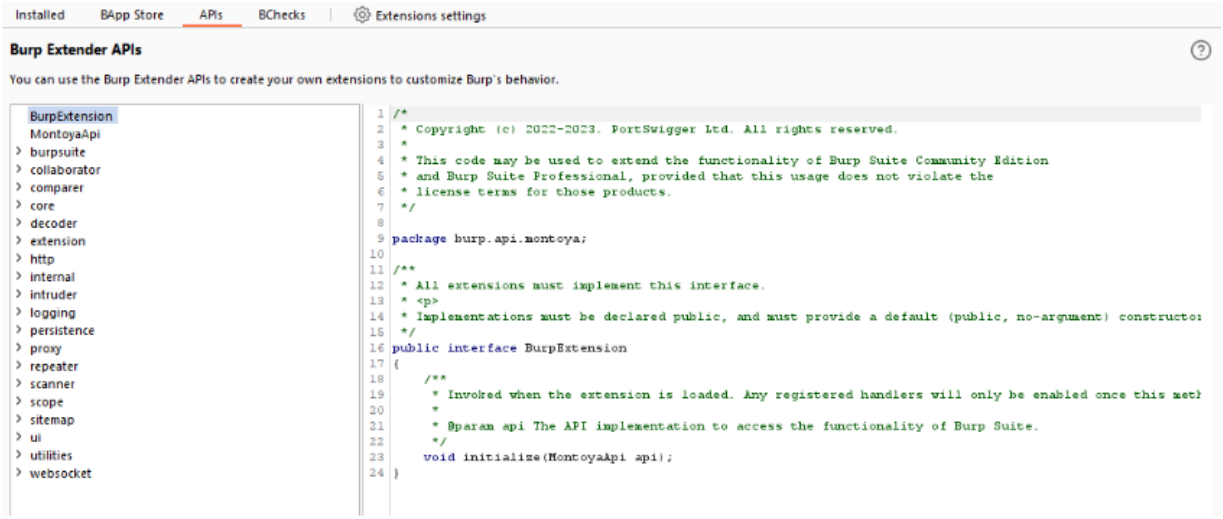




Task 5: The Burp Suite API

In the Burp Suite Extensions module, you have access to a wide range of API endpoints that allow you to create and integrate your modules with Burp Suite.

These APIs expose various functionalities, enabling you to extend the capabilities of Burp Suite to suit your specific needs. To view the available API endpoints, navigate to the **APIs** sub-tab within the Extensions module. Each item listed in the left-hand panel represents a different API endpoint that can be accessed from within extensions.



The Extensions APIs give developers significant power and flexibility when writing custom extensions. You can use these APIs to seamlessly interact with Burp Suite's existing functionality and tailor your extensions to perform specific tasks. It's important to note that coding your extensions for Burp Suite can be a complex task, and it goes beyond the scope of this module. However, suppose you are interested in exploring this area further and creating custom extensions. In that case, PortSwigger provides a comprehensive reference that is an excellent resource for developing Burp Suite extensions.

Task 6: Conclusion

You now have a solid understanding of how to:

Install and manage extensions from the BApp store to extend Burp Suite's capabilities.
Integrate Jython to leverage Python modules within Burp Suite.
Explore the APIs allowing you to develop custom Java, Python, or Ruby modules.

With these skills, you can utilize the Burp Suite Extensions module to its fullest potential in your web application security testing and vulnerability assessments.